QUALITY CONTROL REPORT (QC)

CampusPool â€” Defect Verification, Analytics & Register

CampusPool â€” Inter-Collegiate & University Carpool Finder Â· carpool.33.jugaar.ai

About the project (brief). CampusPool is a website where university students share car journeys. A student who drives posts a ride (from, to, date, time, seats, cost per seat); other students search for rides that match their route, book a seat, chat with the driver, pay online (the payment gateway runs in simulated/sandbox mode), and rate each other afterwards. It also advertises extras such as smart matching, achievements, premium plans and a marketplace. Purpose of this study: the app is our SQET/ST coursework project â€” we examined it end-to-end with 133 testing techniques and reported every defect in the Lewis Book bug format. **Technology:** React 18 + Vite frontend Â· Express + Sequelize backend Â· JWT login Â· Caddy + PM2 server. **Live at:** https://carpool.33.jugaar.ai Â· **Code:** https://github.com/tehzeebshahs4s-hub/qc_report.

Tehzeeb	University of Karachi	Hussain Saleem	8 October 2026
Student / Prepared by	Institution	Course Head	Report date

B23110106073	SQET/ST	Report v2.0	github.com/tehzeebshahs4s-hub/qc_report
Seat number	Subject	Document version	Source repository

Author contact: tehzeebwaliya@gmail.com Â· 03169031194

1 Â· Purpose & Verdict

This **Quality Control (QC)** volume reports the *product-inspection* side of the CampusPool quality programme: what was verified, what failed, with how much risk, and what must be fixed. All entries trace to the 8 October 2026 field campaign; the companion **QA volume** documents process, techniques bundle and prevention planning.

108	84	24	133
Total findings	Field-tested defects	Assessed gaps (QC-logged)	Techniques behind the evidence

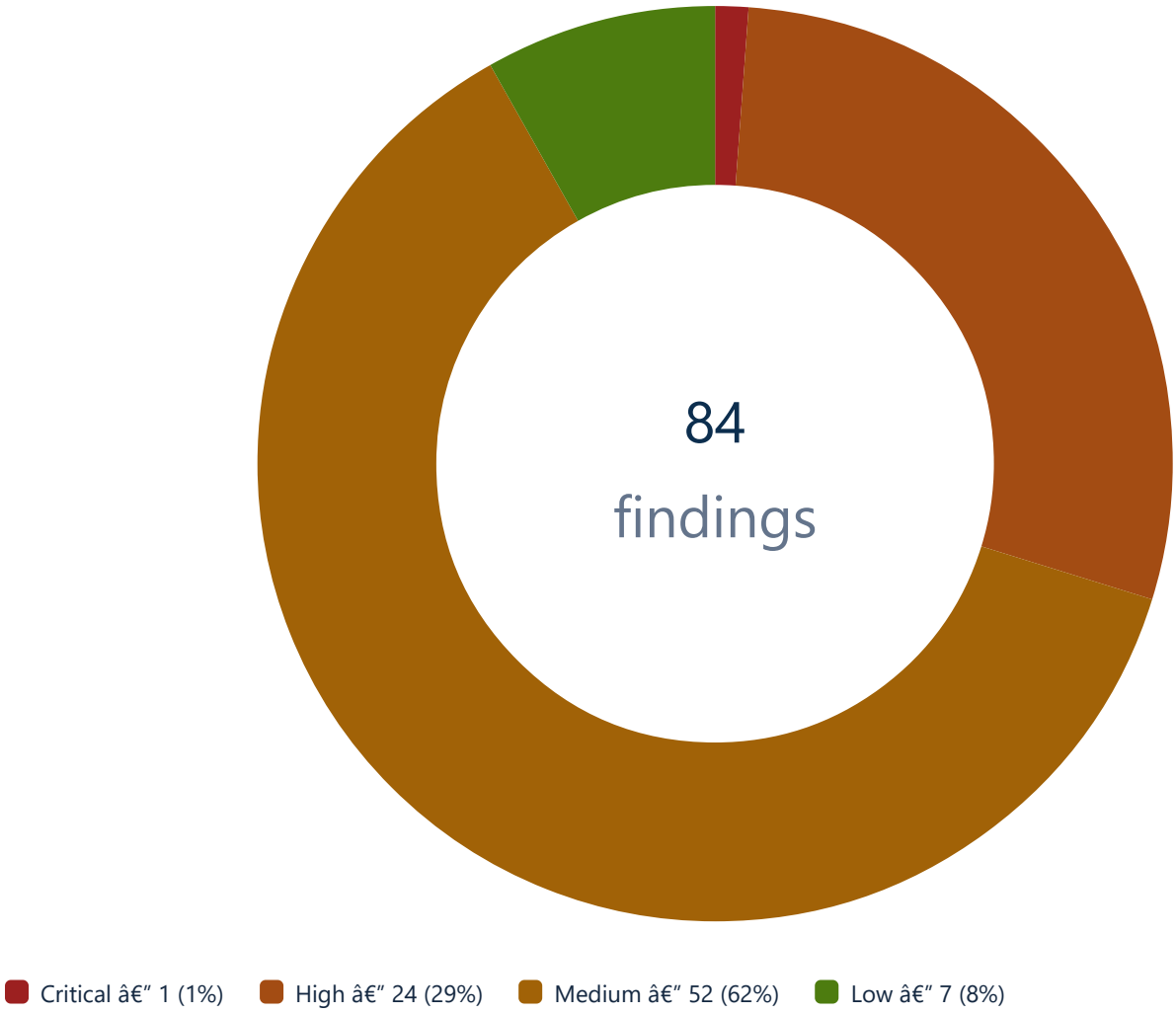
Metric	Value
Field defects	**84** â€" 1 Critical Â· 24 High Â· 52 Medium Â· 7 Low
Release-readiness	**NOT READY for real-users release** â€" launch blockers: API-094 (DB wiped every boot), CR-14 (seat oversell race), API-095 (fake payments shown as real), API-080/081 (any-string verification), API-074/UI-006 (public PII), CR-01 (committed secrets).
Application	CampusPool â€" https://carpool.33.jugaar.ai â€" React 18 + Vite Â· Express + Sequelize Â· JWT Â· Caddy + PM2
Environment / window	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Author / contact	Tehzeeb (B23110106073) â€" University of Karachi â€" tehzeebwaliya@gmail.com Â· 03169031194

2 Â· QA vs QC â€" framing

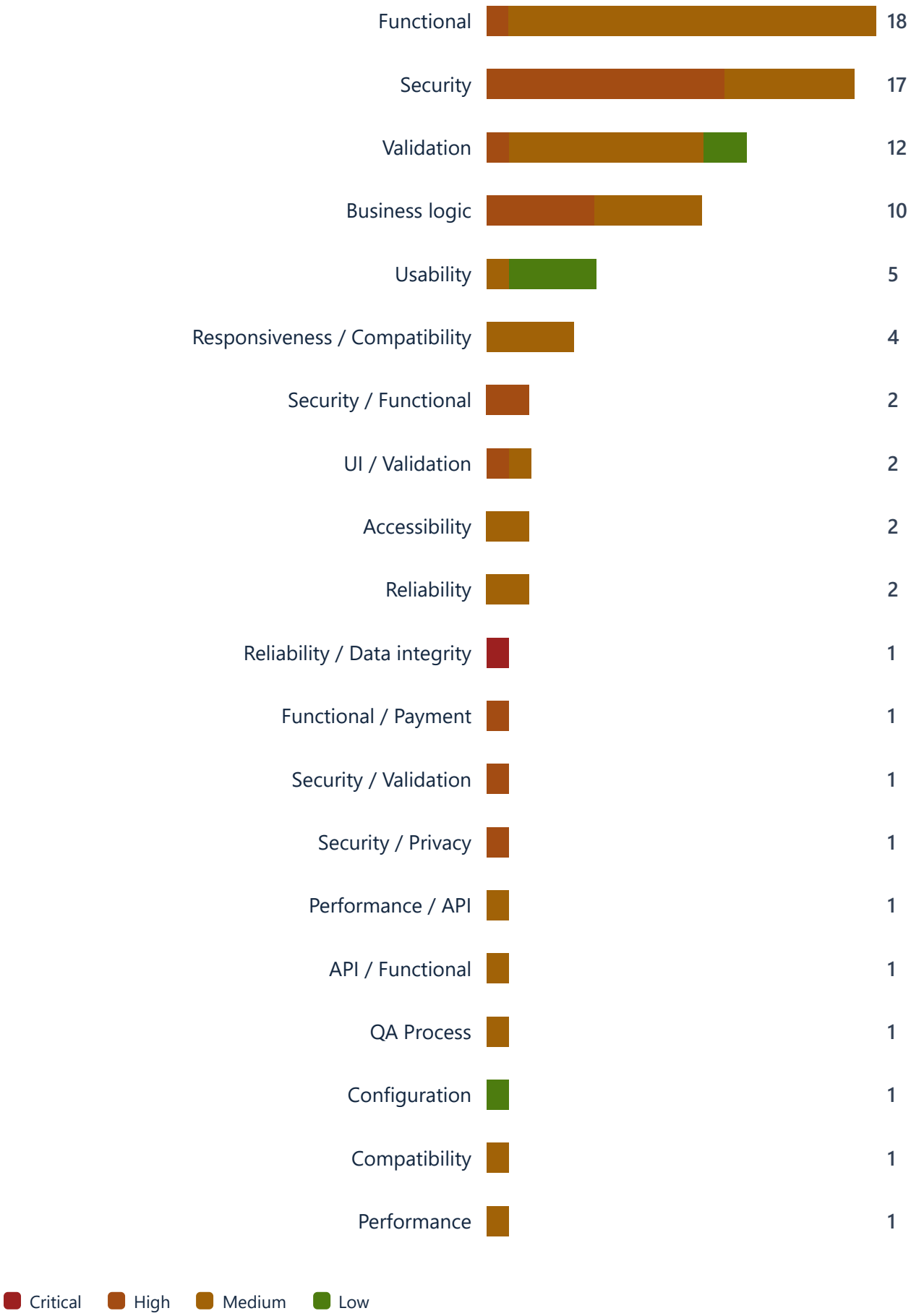
Aspect	Quality Assurance (QA)	Quality Control (QC)
Focus	Prevent defects: process, standards, planning	Identify defects in the work product itself
Orientation	Metric & process-oriented	Product-oriented
Nature	Proactive, continuous improvement	Reactive, corrective
Scope	Entire SDLC	Software testing & inspection of outputs
Example	Requirements traceability matrix for acceptance criteria	Testing the actual ride-search feature for failures
Responsibility	Entire team	QC instrumentation (this report)

3 Â· Defect analytics (charts & tables)

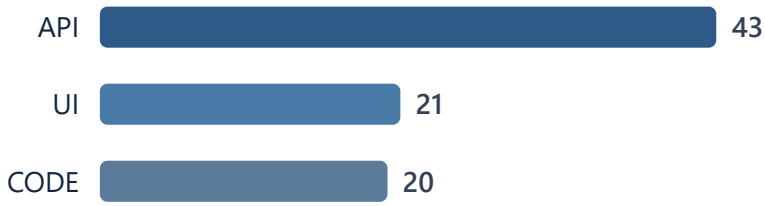
3.1 Severity distribution



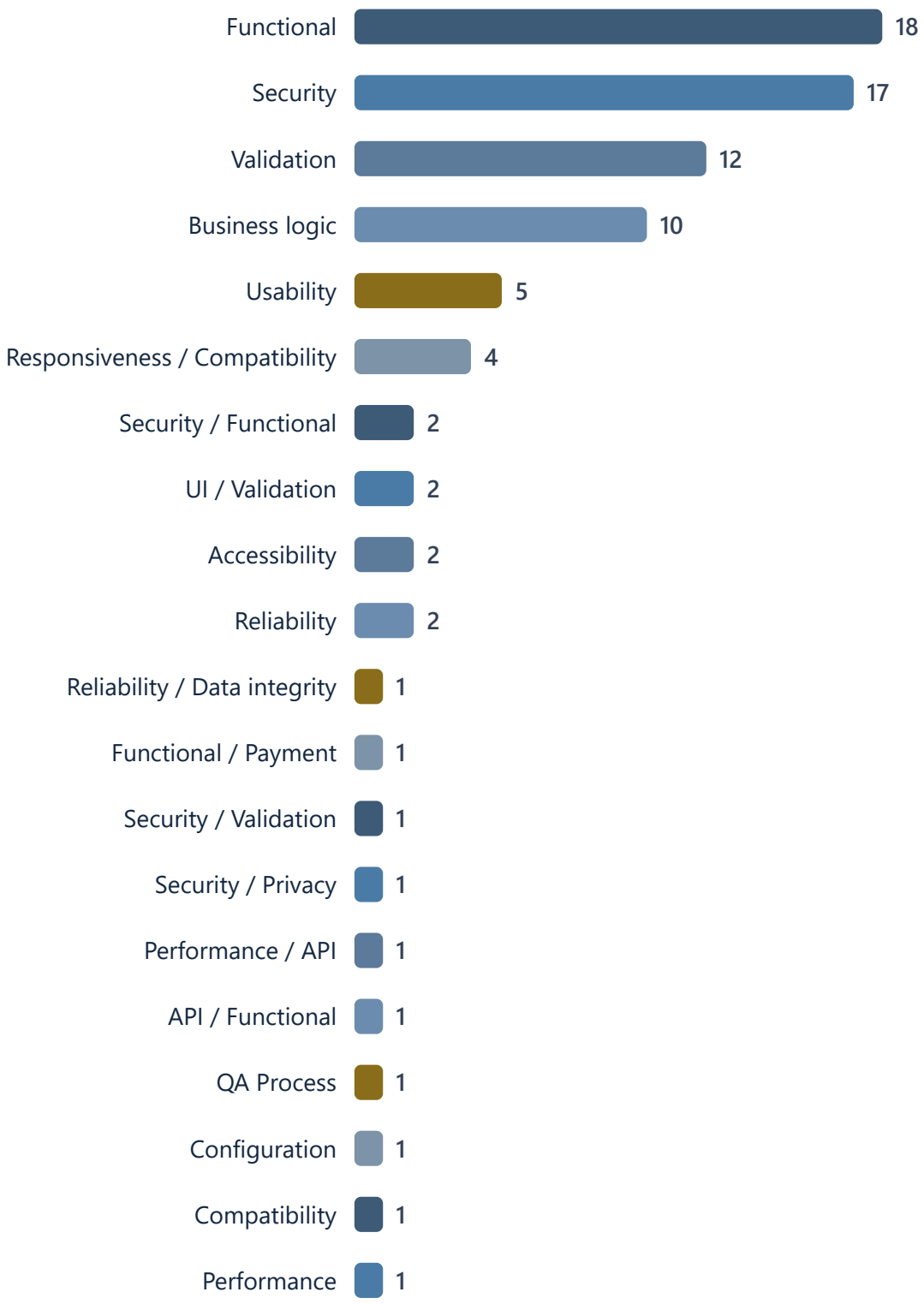
3.2 Findings by category â€” stacked by severity



3.3 Defects by source surface

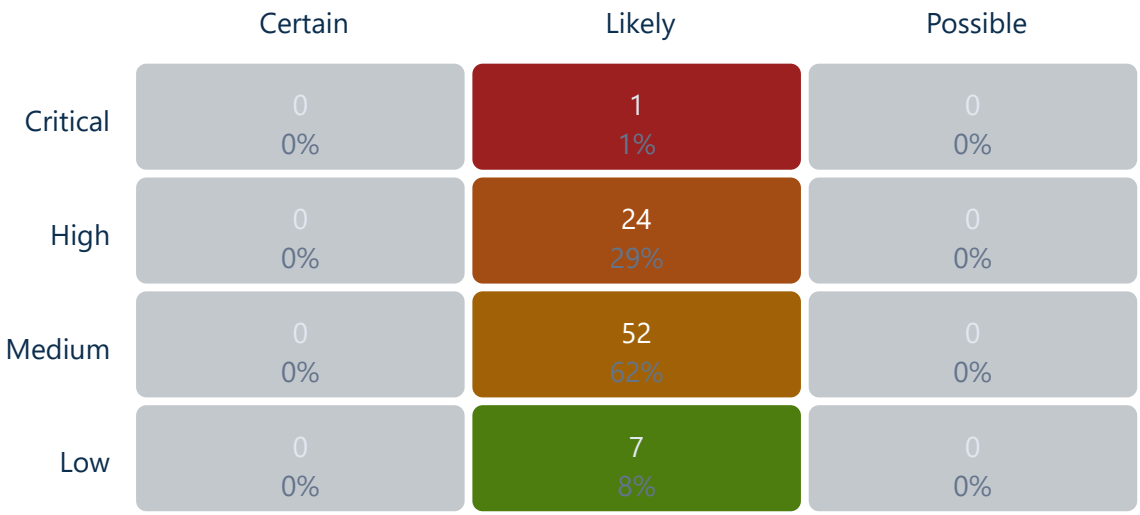


3.4 Category detail (counts)



3.5 Risk-exposure matrix

Likelihood classes (assumption documented): **Certain** = closed-group/vector reproducible (CR security & config items) Â· **Likely** = reachable in normal user flows Â· **Possible** = latent, blocked behind another defect.


Certain
Likely
Possible
Critical
0
0%
1
1%
0
0%
High
0
0%
24
29%
0
0%
Medium
0
0%
52
62%
0
0%
Low
0
0%
7
8%
0
0%

4 Â· Simulation-based QC â€” methods, tools, graphical view & result

What this section contains (the four required parts): â‘ **Simulation Methods** (4.1 â€” the virtual stand-ins we used) Â· â‘¡ **Simulation Tools** (4.2 â€” the software doing the simulating) Â· â‘¢ **Graphical View** (4.3 â€” Figures Aâ€“D plotted from a real run) Â· â‘£ **Result** (4.4 â€” the numbers and what they mean for release).

A real carpool launch involves thousands of simultaneous students, dozens of phone/tablet models and congested networks â€” impossible to stage in a university project window. QC therefore used **simulation methods**: controlled stand-ins that make a system behave as-if under conditions we could not otherwise produce, while keeping every observation traceable to a scripted driver. Live run performed 2026-11-07 12:00:22; ethics/scope: public GET endpoints only, ~45 requests (comparable to one student browsing), no destructive requests.

4.1 Simulation methods applied (with the defects they exposed)

Simulation method	What it simulated	Driver/tool	Evidence it produced
Device / display emulation	Four virtual viewports: iPhone SE 375Ã—667, iPhone 14 390Ã—844, Galaxy S 360Ã—740, small desktop 1024Ã—768	Playwright device emulation + Chrome DevTools device mode	Cross-viewport horizontal-overflow defects **UI-028â€¦UI-032** (Section 4.4)
Virtual-user load simulation	5 concurrent synthetic users (each 4 requests, staggered) â†’ concurrency & latency profile without real crowds	Python `requests` + `ThreadPoolExecutor`	Run summary & percentile profile (Section 4.4)
State-machine sequence replay	Ride/booking lifecycle chains replayed as ordered HTTP calls (create â†’ book â†’ confirm â†’ complete/cancel)	Scripted agent (Playwright + requests)	State defects **API-047/048** (cancels with active bookings), **API-085** (self-confirm), **API-084** (double-cancel seat inflation), **API-087** (complete-while-active)
Data-driven input simulation	Boundary & equivalence-partition payload sets (seats 0/âˆ’1/8, price 0/âˆ’1, past dates, malformed CNIC, empty message)	Scripted payloads from technique matrix	Validation defects **API-016â€¦API-021**, **API-019/020**, **API-060**, **API-080/081**
Payment gateway simulation analysis	Production gateway already runs in *simulation mode* (mocked PSP) — QC verified user-facing honesty of that simulation	Code review + UI observation	**API-095** — fake success screen presented as real (critical business honesty defect)
Failure-injection probes	Invalid JWT manipulation, dead routes, oversized search limits (999999)	curl/Playwright probes	**API-026**, **API-035/017** handling, **17_a11y** console errors

4.2 Simulation tools roster (role + adoption status)

Tool	Role in QC simulation	Status
Playwright (Python)	Device-emulated UI journeys, scripted API sequence replays, evidence capture	Used
Chrome DevTools	Device mode, console/network observation, throttled profiling	Used
Python requests + ThreadPoolExecutor	Virtual-user phase; latency percentiles; availability probes	Used
Chrome headless	Headless render of pages & print-capture of this report	Used
curl / PowerShell HTTP	Point probes; payload inspection; re-verification	Used
k6 / JMeter	Production-grade sustained load profile, soak & spike tests â€" *not run in the coursework window*	Recommended
OWASP ZAP	Automated DAST crawl on top of the manual security probes	Recommended

4.3 Graphical view â€" live simulation run 2026-11-07 12:00:22

Figure A â€" sequential response-time profile, SPA root (25 requests): certainly not â€œsnappyâ€ at the gateway; median 1020.2 ms and spikes to 2242.8 ms. **Figure B** â€" mean response per virtual user under tiny concurrency: consistent ~1 s gateway latency. **Figure C** â€" availability snapshot: public SPA healthy (200) while the **API behind the proxy returns 502 â€" the backend service was DOWN at re-verification time** (recorded today as an availability observation, dated; the Oct-8 campaign data is unaffected). **Figure D** â€" device-emulation findings mapped from the register.

FIGURE A Â· SEQUENTIAL RESPONSE-TIME (MS) Â€" 25 REQUESTS

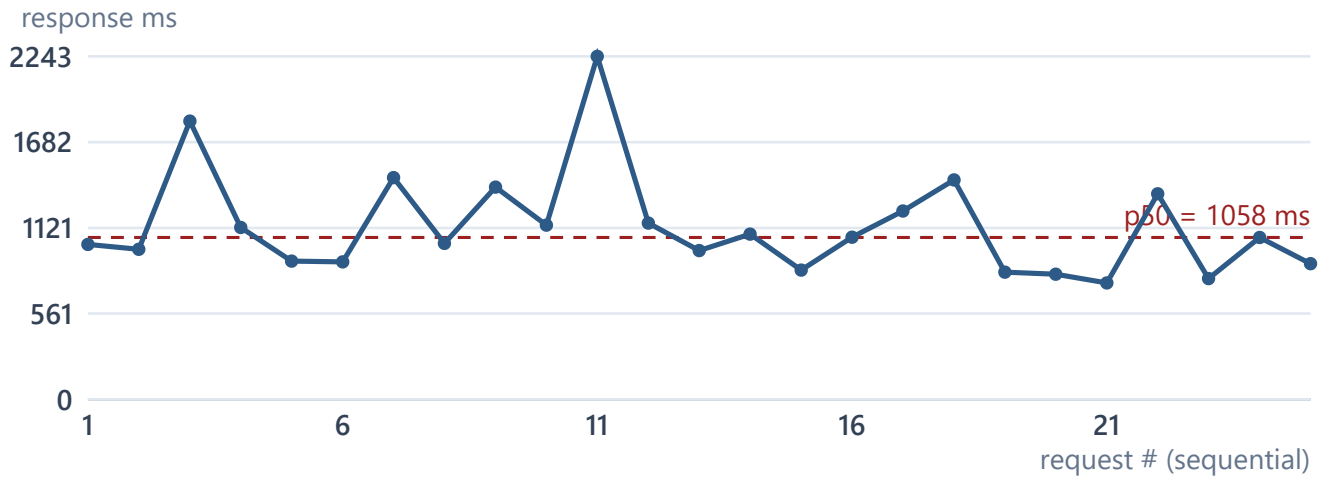


FIGURE B Â· MEAN RESPONSE PER VIRTUAL USER (MS)

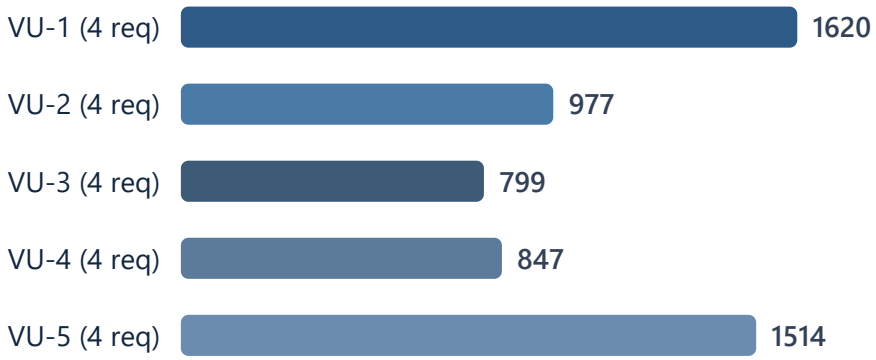


FIGURE C Â· ENDPOINT AVAILABILITY SNAPSHOT



FIGURE D Â· DEVICE-EMULATION OVERFLOW FINDINGS (PER EMULATED DEVICE)



4.4 Result (what the simulation run showed)

Run metric	Value (45 samples)
Median (p50) response	**1020.2 ms**
Mean response	1139.4 ms
90th percentile (p90)	1450.0 ms
Maximum spike	2242.8 ms
Throughput at tiny concurrency	0.88 req/s
HTTP 200 share (SPA)	100 % of SPA-path requests succeeded
API availability	**502 â€" backend down at re-verification** (proxy healthy, origin unhealthy)

1. **Device simulation verdict:** 4 of the emulated wide-device profiles exhibit horizontal-overflow layout defects â€" the responsive experience is not production-ready (UI-028â€¦UI-032).
2. **Virtual-user verdict:** under the deliberately light synthetic load the SPA stayed 100 % successful, but gateway latency (p50 â‰ˆ 1020.2 ms, p90 â‰ˆ 1450.0 ms) shows no CDN/edge optimisation â€" matches recommendation MF-20 (performance engineering).
3. **Availability verdict:** 2026-11-07 12:00:22 â€" API origin down (502) while static SPA serves normally; production continuity depends on a single origin without failover or monitoring (tie-in: MF-21 observability, MF-22 backup/DR).
4. **State & data-driven replay verdict:** replayed chains reproduced 9 state/validation defects â€" simulation methods here are directly traceable to the register.

Scope honesty: this is a light-scale coursework simulation, not a certified load test; percentiles must be re-established with k6/JMeter at production scale (MF-20) before capacity claims. The availability 502 recurred across every probe during the run window â€" classify as environment observation, not counted among the 84 October defects.

5 Â· Defect register â€” field-tested (84)

#	ID	Summary (detail in Section 7)	Sev	Priority	Category	Src	Status
1	**API-094**	sequelize.sync({force:true}) on every server start wipes DB	Critical	P1 - Immediate	Reliability / Data integrity	API	Open
2	**API-006**	XSS payload in fullName during registration	High	P2 - High	Security	API	Open
3	**API-007**	Stored XSS payload in profile response	High	P2 - High	Security	API	Open
4	**API-020**	Create ride with past departure time accepted	High	P2 - High	Validation	API	Open
5	**API-022**	XSS payload in ride notes	High	P2 - High	Security	API	Open
6	**API-043**	Ride update mass-assignment (status/driverId/availableSeats)	High	P2 - High	Security	API	Open
7	**API-044**	Ride state after mass-assignment update	High	P2 - High	Security	API	Open
8	**API-047**	Driver cancels ride with active bookings	High	P2 - High	Business logic	API	Open
9	**API-048**	Passenger booking status after ride cancel	High	P2 - High	Business logic	API	Open
10	**API-054**	Rating/review workflow unreachable - no completed-ride path	High	P2 - High	Business logic	API	Open
11	**API-061**	XSS in message content	High	P2 - High	Security	API	Open
12	**API-074**	Unauthenticated ride detail exposes driver phone	High	P2 - High	Security	API	Open
13	**API-080**	Student verification without real check — arbitrary CNIC accepted	High	P2 - High	Security / Functional	API	Open
14	**API-081**	Verify with garbage CNIC accepted	High	P2 - High	Security / Validation	API	Open
15	**API-084**	Double-cancel booking inflates seats	High	P2 - High	Business logic	API	Open
16	**API-085**	Passenger self-confirms own booking	High	P2 - High	Business logic	API	Open
17	**API-091**	Review rating bounds unvalidated (latent) - rating=99 rejected only by workflow gate	High	P2 - High	Security	API	Open
18	**API-095**	Payment gateway fully simulated — no real JazzCash/EasyPaisa/bank	High	P2 - High	Functional / Payment	API	Open
19	**CR-01**	Hardcoded JWT secrets committed to repository	High	P2 - High	Security	CODE	Open
20	**CR-09**	Sanitize middleware stores HTML-encoded data (double-encoding)	High	P2 - High	Security	CODE	Open
21	**CR-12**	JWT in localStorage with no server-side revocation	High	P2 - High	Security	CODE	Open
22	**UI-006**	Search free-text filter ignored — unrelated rides returned	High	P2 - High	Functional	UI	Open

23	**UI-007**	Ride details exposes driver phone publicly	High	P2 - High	Security / Privacy	UI	Open
24	**UI-015**	Student verification fake — hardcoded CNIC / no real check	High	P2 - High	Security / Functional	UI	Open
25	**UI-027**	Create Ride past date + 0 seats submit	High	P2 - High	UI / Validation	UI	Open
26	**API-016**	Create ride 0 seats - generic error message (validation hidden)	Medium	P3 - Medium	Validation	API	Open
27	**API-017**	Create ride negative seats - generic error message	Medium	P3 - Medium	Validation	API	Open
28	**API-018**	Create ride negative price - generic error message	Medium	P3 - Medium	Validation	API	Open
29	**API-019**	Create ride with 0 price	Medium	P3 - Medium	Validation	API	Open
30	**API-021**	Create ride seats>7 - generic error message	Medium	P3 - Medium	Validation	API	Open
31	**API-024**	Search by free-text origin/destination ignored — returns unrelated rides	Medium	P3 - Medium	Functional	API	Open
32	**API-026**	Search limit=999999 resource abuse	Medium	P3 - Medium	Performance / API	API	Open
33	**API-029**	Book ride 0 seats - generic Failed to create booking message	Medium	P3 - Medium	Business logic	API	Open
34	**API-031**	Book ride negative seats - generic error message (validation hidden)	Medium	P3 - Medium	Business logic	API	Open
35	**API-038**	Booking creation fails with opaque generic errors	Medium	P3 - Medium	Business logic	API	Open
36	**API-050**	Payment with unlisted method accepted	Medium	P3 - Medium	Validation	API	Open
37	**API-060**	Send empty message content	Medium	P3 - Medium	Validation	API	Open
38	**API-065**	Fetch other user's profile by ID (PII exposure)	Medium	P3 - Medium	Security	API	Open
39	**API-076**	Profile update attempts email change (ignored silently)	Medium	P3 - Medium	Functional	API	Open
40	**API-077**	Profile update attempts password change via profile (ignored)	Medium	P3 - Medium	Functional	API	Open
41	**API-079**	Profile update invalid phone	Medium	P3 - Medium	Validation	API	Open
42	**API-087**	Driver marks booking completed while ride still active	Medium	P3 - Medium	Business logic	API	Open
43	**API-089**	Duplicate review prevention not reachable/unverified	Medium	P3 - Medium	Business logic	API	Open
44	**API-090**	Review rating bounds unvalidated when review path opens	Medium	P3 - Medium	Validation	API	Open
45	**API-093**	User search endpoint broken	Medium	P3 - Medium	API / Functional	API	Open

46	**API-097**	CORS allowlist includes raw IP origins (67.215.237.229)	Medium	P3 - Medium	Security	API	Open
47	**API-098**	JWT expiry 7 days + localStorage + no server revoke	Medium	P3 - Medium	Security	API	Open
48	**API-099**	Forgot password feature completely missing (UI link dead + no API)	Medium	P3 - Medium	Functional	API	Open
49	**CR-02**	No admin/moderation pages despite feature claims	Medium	P3 - Medium	Functional	CODE	Open
50	**CR-03**	Recurring rides stored but never expanded into actual rides	Medium	P3 - Medium	Functional	CODE	Open
51	**CR-04**	No automated test suite in repository	Medium	P3 - Medium	QA Process	CODE	Open
52	**CR-05**	Broken deploy configs (Procfile / render.yaml)	Medium	P3 - Medium	Reliability	CODE	Open
53	**CR-07**	Demo credentials printed by start.sh in cleartext	Medium	P3 - Medium	Security	CODE	Open
54	**CR-08**	No email verification / SMTP integration	Medium	P3 - Medium	Functional	CODE	Open
55	**CR-10**	Generic error messages hide field-level validation failures	Medium	P3 - Medium	Reliability	CODE	Open
56	**CR-11**	User search API endpoint broken	Medium	P3 - Medium	Functional	CODE	Open
57	**CR-13**	DataTypes.ARRAY may break on SQLite dialect	Medium	P3 - Medium	Compatibility	CODE	Open
58	**CR-14**	Seat booking race condition (no transaction/atomic decrement)	Medium	P3 - Medium	Performance	CODE	Open
59	**CR-16**	Public ride detail exposes driver phone	Medium	P3 - Medium	Security	CODE	Open
60	**CR-17**	Profile update silently ignores empty/fullName edge cases	Medium	P3 - Medium	Functional	CODE	Open
61	**CR-19**	Rate limiting missing on reviews/messages/safety/impact/users	Medium	P3 - Medium	Security	CODE	Open
62	**CR-20**	Impact/Emergency/PublicProfile pages use mock data only	Medium	P3 - Medium	Functional	CODE	Open
63	**UI-001**	'Forgot password' dead link	Medium	P3 - Medium	Usability	UI	Open
64	**UI-008**	Premium page — mock/hardcoded data (no real API)	Medium	P3 - Medium	Functional	UI	Open
65	**UI-009**	Earnings page — mock/hardcoded data (no real API)	Medium	P3 - Medium	Functional	UI	Open
66	**UI-010**	Achievements page — mock/hardcoded data (no real API)	Medium	P3 - Medium	Functional	UI	Open
67	**UI-011**	Smart Match page — mock/hardcoded data (no real API)	Medium	P3 - Medium	Functional	UI	Open
68	**UI-012**	Marketplace page — mock/hardcoded data (no real API)	Medium	P3 - Medium	Functional	UI	Open

69	**UI-013**	Sponsored page — mock/hardcoded data (no real API)	Medium	P3 - Medium	Functional	UI	Open
70	**UI-014**	Cities page — mock/hardcoded data (no real API)	Medium	P3 - Medium	Functional	UI	Open
71	**UI-026**	Create Ride empty submit validation	Medium	P3 - Medium	UI / Validation	UI	Open
72	**UI-028**	Responsive iphone_se 375x667 horizontal overflow	Medium	P3 - Medium	Responsiveness / Compatibility	UI	Open
73	**UI-029**	Responsive iphone_14 390x844 horizontal overflow	Medium	P3 - Medium	Responsiveness / Compatibility	UI	Open
74	**UI-030**	Responsive galaxy_s 360x740 horizontal overflow	Medium	P3 - Medium	Responsiveness / Compatibility	UI	Open
75	**UI-032**	Responsive desktop_small 1024x768 horizontal overflow	Medium	P3 - Medium	Responsiveness / Compatibility	UI	Open
76	**UI-036**	Accessibility spot-check home	Medium	P3 - Medium	Accessibility	UI	Open
77	**UI-037**	Accessibility spot-check search	Medium	P3 - Medium	Accessibility	UI	Open
78	**API-025**	Search minSeats=-10 unvalidated	Low	P4 - Low	Validation	API	Open
79	**API-027**	Search with invalid departureDate	Low	P4 - Low	Validation	API	Open
80	**CR-06**	PORT inconsistency (5000 vs 5001 defaults)	Low	P4 - Low	Configuration	CODE	Open
81	**CR-15**	Real-time chat is polling only (30s interval)	Low	P4 - Low	Usability	CODE	Open
82	**CR-18**	README claims unimplemented features (notifications, maps, admin)	Low	P4 - Low	Usability	CODE	Open
83	**UI-002**	'Remember me' checkbox cosmetic / non-functional	Low	P4 - Low	Usability	UI	Open
84	**UI-035**	Unknown route handling (404)	Low	P4 - Low	Usability	UI	Open

6 Â· Assessed gaps carried on the QC register (24)

Requirement gaps are logged on the QC side for tracking (acceptance criteria live in the QA volume). Framing: assessed, not field-reproduced.

Gap	Missing capability	Domain	Priority	Impact if live	Status
MF-01	Password reset & account recovery flow	Authentication	P1 - Immediate	High	Open
MF-02	E-mail delivery infrastructure (SMTP)	Authentication	P2 - High	High	Open
MF-03	Admin & moderation backend	Governance	P2 - High	High	Open
MF-04	User reporting / abuse escalation	Governance	P2 - High	Medium	Open
MF-05	Driver verification / KYC (licence & vehicle documents)	Safety	P1 - Immediate	High	Open
MF-06	Complete ride -> review path (workflow closure)	Bookings	P2 - High	High	Open
MF-07	Seat inventory protection under concurrency	Bookings	P1 - Immediate	High	Open
MF-08	Notification service (in-app, e-mail, push)	Communication	P2 - High	Medium	Open
MF-09	Real-time messaging (WebSocket/SSE)	Communication	P3 - Medium	Medium	Open
MF-10	Live ride tracking & location sharing	Safety	P3 - Medium	Medium	Open
MF-11	Map / geocoding / route integration	Rides	P2 - High	Medium	Open
MF-12	Real payment gateway + passenger protection (hold/escrow)	Payments	P1 - Immediate	Critical-when-live	Open
MF-13	Refund lifecycle execution	Payments	P2 - High	Medium	Open
MF-14	Cancellation policy & no-show rules	Bookings	P2 - High	Medium	Open
MF-15	Recurring rides expansion	Rides	P3 - Medium	Low	Open
MF-16	Women-only / preferences safety filters	Safety	P2 - High	Medium	Open
MF-17	Legal & trust content (privacy policy, terms)	Governance	P2 - High	Medium	Open
MF-18	Account deletion & data export	Governance	P2 - High	Low	Open
MF-19	Earnings back-end for drivers	Payments	P3 - Medium	Low	Open
MF-20	Performance & load engineering (NFR)	Non-functional	P2 - High	Medium	Open
MF-21	Observability: logging, error tracking, uptime	Operations	P2 - High	Medium	Open
MF-22	Backup, restore & disaster recovery drill	Operations	P2 - High	High	Open
MF-23	CI/CD with automated test gates	Operations	P2 - High	High	Open
MF-24	Analytics & events (privacy-safe)	Non-functional	P3 - Medium	Low	Open

7 Â· Detailed defect pages (84)

Critical **API-094** P1 - Immediate Status: Open

[API-094] sequelize.sync({force:true}) on every server start wipes DB

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Reliability / Data integrity
Technique(s)	Static analysis / code review
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. backend/src/index.ts:107 sequelize.sync({ force: true })

EXPECTED RESULT (ORACLE)

Use migrations / sync({force:false}); never drop production data on boot.

ACTUAL RESULT (PROOF)

```
sequelize.sync({ force: true }) on every server start  deletes all users, rides, bookings, messages; reseeds 3 demo users.
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Data loss is a release-blocking reliability defect

High **API-006** P2 - High Status: Open

[API-006] XSS payload in fullName during registration

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Security testing (XSS / input validation)
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /auth/register fullName=<script>alert(1)</script>

EXPECTED RESULT (ORACLE)

Input must be safely stored/rendered

ACTUAL RESULT (PROOF)


```
{"success": true, "message": "Registration successful", "data": {"user": {"id": "e213e7d8-f2d6-464b-a8dd-6e4728ad76f0", "email": "xss.021c10e3@uok.edu.pk", "fullName": "&lt;script&gt;alert(&#x27;xss&#x27;)&lt;/script&gt;", "phone": "+923001112233", "university": "UoK", "isVerified": false, "isDriver": false, "rating": 0}, "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VySWQiOiJlMjEzZTdkOC1mMmQ2LTQ2NGItYThkZC02ZTQ3MjhhZDc2ZjAiLCJpYXQiOjE3OTE0NTM0MjUsImV4cCI6MTc5MjA1ODIyNX0.abYGxwDEYSjE-HL_H76PH9-GcDld2qkbbTq1U4KQZZs"}}
```


SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

High **API-007** P2 - High Status: Open

[API-007] Stored XSS payload in profile response

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Security testing (XSS)
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. GET /auth/profile after XSS register

EXPECTED RESULT (ORACLE)

Stored script tags indicate broken sanitize middleware

ACTUAL RESULT (PROOF)


```
{"success": true, "data": {"user": {"id": "e213e7d8-f2d6-464b-a8dd-6e4728ad76f0", "email":
"xss.021c10e3@uok.edu.pk", "fullName": "&lt;script&gt;alert(&#x27;xss&#x27;)&lt;/script&gt;",
"phone": "+923001112233", "university": "UoK", "department": null, "yearOfStudy": null,
"profilePhoto": null, "isVerified": false, "isDriver": false, "rating": 0, "totalRides": 0,
"createdAt": "2026-10-08T09:57:05.829Z"}}}
```


SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

raw fullName stored as: "<script>alert('xss')</script>"

High **API-020** P2 - High Status: Open

[API-020] Create ride with past departure time accepted

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Validation
Technique(s)	State transition / business rules
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /rides departureTime in past

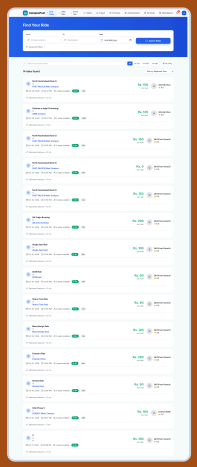
EXPECTED RESULT (ORACLE)

Past departures must not be created as active future rides

ACTUAL RESULT (PROOF)


```
{"success": true, "message": "Ride created successfully", "data": {"ride": {"id": "a52e523c-45c6-4dfa-877d-d1da89e31470", "status": "active", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName": "North Nazimabad Block D", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "FAST-NUCES Main Campus", "departureTime": "2026-10-08T04:58:06.497Z", "availableSeats": 3, "pricePerSeat": 150, "isRecurring": false, "vehicleType": "Car", "hasAC": true, "notes": "QA test ride", "updatedAt": "2026-10-08T09:58:06.507Z", "createdAt": "2026-10-08T09:58:06.507Z"}}}
```


SCREENSHOTS



ðŸ"¸ 15_console_errors_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

High **API-022** P2 - High Status: Open

[API-022] XSS payload in ride notes

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Security testing (XSS)
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /rides notes=<img onerror=...>

EXPECTED RESULT (ORACLE)

Notes must not store executable HTML raw

ACTUAL RESULT (PROOF)


```
{"success": true, "message": "Ride created successfully", "data": {"ride": {"id": "f11377c9-1033-4f4b-82fa-dafe3a3a22e0", "status": "active", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName": "North Nazimabad Block D", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "FAST-NUCES Main Campus", "departureTime": "2026-10-10T09:58:06.532Z", "availableSeats": 3, "pricePerSeat": 150, "isRecurring": false, "vehicleType": "Car", "hasAC": true, "notes": "&lt;img src=x onerror=alert(1)&gt;", "updatedAt": "2026-10-08T09:58:06.539Z", "createdAt": "2026-10-08T09:58:06.539Z"}}}
```


SCREENSHOTS



ðŸ", 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

High **API-043** P2 - High Status: Open

[API-043] Ride update mass-assignment (status/driverId/availableSeats)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Mass assignment testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. PUT /rides/91c6e7c8-3f81-4f13-8f3a-98d40c2f2df5 body includes status/driverId

EXPECTED RESULT (ORACLE)

Update must whitelist fields; caller must not set arbitrary status or transfer ownership

ACTUAL RESULT (PROOF)

```
{"success": false, "message": "Failed to update ride"}
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

High **API-044** P2 - High Status: Open

[API-044] Ride state after mass-assignment update

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Mass assignment testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. GET /rides/91c6e7c8-3f81-4f13-8f3a-98d40c2f2df5

EXPECTED RESULT (ORACLE)

Verify which fields were actually persisted

ACTUAL RESULT (PROOF)


```
{"success": true, "data": {"ride": {"id": "91c6e7c8-3f81-4f13-8f3a-98d40c2f2df5", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName": "MassAssign Ride", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "MassAssign Dest", "departureTime": "2026-10-10T09:59:21.651Z", "availableSeats": 2, "pricePerSeat": 120, "isRecurring": false, "recurringDays": null, "status": "active", "vehicleType": "Car", "vehicleMake": null, "licensePlate": null, "hasAC": true, "notes": "QA test ride", "createdAt": "2026-10-08T09:59:21.749Z", "updatedAt": "2026-10-08T09:59:21.749Z", "driver": {"id": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "fullName": "QA Driver Karachi", "university": "University of Karachi", "rating": 0, "profilePhoto": null, "phone": "+923009001101"}}}}
```


SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

stored status=active

High **API-047** P2 - High Status: Open

[API-047] Driver cancels ride with active bookings

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Business logic
Technique(s)	State transition testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /rides/c689e47b-148e-4415-be35-6c1ac19cc201/cancel

EXPECTED RESULT (ORACLE)

Cancelling a ride must cascade: cancel bookings, restore/adjust seats, notify passengers

ACTUAL RESULT (PROOF)

```
{"success": true, "message": "Ride cancelled successfully"}
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

High **API-048** P2 - High Status: Open

[API-048] Passenger booking status after ride cancel

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Business logic
Technique(s)	State transition testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. GET /bookings/my-bookings (ride c689e47b-148e-4415-be35-6c1ac19cc201)

EXPECTED RESULT (ORACLE)

Booking on cancelled ride must not stay pending/confirmed stranded passenger

ACTUAL RESULT (PROOF)


```
{"success": true, "data": {"bookings": [{"id": "4be293b4-631d-4ecd-b757-b9bcc6f2dd58", "rideId":
"c689e47b-148e-4415-be35-6c1ac19cc201", "passengerId": "d8424298-1bb3-490b-84f8-bfb5d878da33",
"seatsBooked": 2, "pickupPoint": "Crater", "status": "pending", "paymentStatus": "pending",
"amountPaid": 200, "createdAt": "2026-10-08T09:59:21.842Z", "updatedAt": "2026-10-08T09:59:21.842Z",
"ride": {"id": "c689e47b-148e-4415-be35-6c1ac19cc201", "driverId": "1a66017f-f150-48f3-91cb-
1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName": "CancelRide Test",
"destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "CancelRide Dest",
"departureTime": "2026-10-10T09:59:21.813Z", "availableSeats": 1, "pricePerSeat": 100,
"isRecurring": false, "recurringDays": null, "status": "cancelled", "vehicleType": "Car",
"vehicleMake": null, "licensePlate": null, "hasAC": true, "notes": "QA test ride", "createdAt":
"2026-10-08T09:59:21.819Z", "updatedAt": "2026-10-08T09:59:21.869Z", "driver": {"id": "1a66017f-
f150-48f3-91cb-1a2b106fa94b", "fullName": "QA Driver Karachi", "univer â€¦(full transcript in
Findings CSV)
```


SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

booking status after ride cancel = pending

High **API-054** P2 - High Status: Open

[API-054] Rating/review workflow unreachable - no completed-ride path

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Business logic
Technique(s)	Business rules testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /reviews without booking

EXPECTED RESULT (ORACLE)

Review system must be reachable after a real completed-ride workflow.

ACTUAL RESULT (PROOF)

```
Driver can cancel ride but no complete-ride flow exists; reviews always blocked with 'Can only review completed rides'.
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Driver can cancel ride but no complete-ride flow exists; reviews always blocked with 'Can only review completed rides'.

High **API-061** P2 - High Status: Open

[API-061] XSS in message content

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Security testing (XSS)
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /messages content=<script>

EXPECTED RESULT (ORACLE)

Message content must be safely stored

ACTUAL RESULT (PROOF)


```
{"success": true, "message": "Message sent successfully", "data": {"message": {"id": "6d25918e-0049-4a1b-bdbb-f776d5f1e6d5", "isRead": false, "senderId": "d8424298-1bb3-490b-84f8-bfb5d878da33", "receiverId": "19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "content": "&lt;script&gt;alert(&#x27;msg&#x27;)&lt;/script&gt;", "updatedAt": "2026-10-08T09:59:22.310Z", "createdAt": "2026-10-08T09:59:22.310Z"}}}
```


SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

High **API-074** P2 - High Status: Open

[API-074] Unauthenticated ride detail exposes driver phone

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Privacy / data exposure testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. GET /rides/91c6e7c8-3f81-4f13-8f3a-98d40c2f2df5 no auth

EXPECTED RESULT (ORACLE)

Driver phone must not be exposed to unauthenticated users

ACTUAL RESULT (PROOF)


```
{"success": true, "data": {"ride": {"id": "91c6e7c8-3f81-4f13-8f3a-98d40c2f2df5", "driverId":
"1a66017f-f150-48f3-91cb-1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName":
"MassAssign Ride", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName":
"MassAssign Dest", "departureTime": "2026-10-10T09:59:21.651Z", "availableSeats": 2, "pricePerSeat":
120, "isRecurring": false, "recurringDays": null, "status": "active", "vehicleType": "Car",
"vehicleMake": null, "licensePlate": null, "hasAC": true, "notes": "QA test ride", "createdAt":
"2026-10-08T09:59:21.749Z", "updatedAt": "2026-10-08T09:59:21.749Z", "driver": {"id": "1a66017f-
f150-48f3-91cb-1a2b106fa94b", "fullName": "QA Driver Karachi", "university": "University of
Karachi", "rating": 0, "profilePhoto": null, "phone": "+923009001101"}}}}
```


SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

phone exposed = +923009001101

High **API-080** P2 - High Status: Open

[API-080] Student verification without real check — arbitrary CNIC accepted

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security / Functional
Technique(s)	Security testing / functional
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /auth/verify cnicNumber=00000-0000000-0

EXPECTED RESULT (ORACLE)

Verification must validate CNIC format and/or require proof

ACTUAL RESULT (PROOF)

```
{"success":true,"message":"Student verification submitted","data":{"isVerified":true}}
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

isVerified=true granted with no validation fake trust badge

High **API-081** P2 - High Status: Open

[API-081] Verify with garbage CNIC accepted

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security / Validation
Technique(s)	Security testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /auth/verify cnicNumber=abc

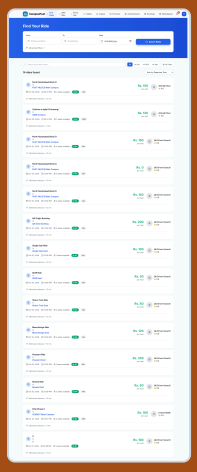
EXPECTED RESULT (ORACLE)

Garbage CNIC must be rejected

ACTUAL RESULT (PROOF)

```
{"success":true,"message":"Student verification submitted","data":{"isVerified":true}}
```

SCREENSHOTS



ðŸ"¸ 15_console_errors_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

No format validation on verification

High **API-084** P2 - High Status: Open

[API-084] Double-cancel booking inflates seats

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Business logic
Technique(s)	State transition testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /bookings/a2240e2e-83fa-4cdc-948f-ff7163176e92/cancel again

EXPECTED RESULT (ORACLE)

Seat count after 2nd cancel = 6 (was 4)

ACTUAL RESULT (PROOF)

```
after=4 after2=6; second cancel must be rejected/no-op
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Inventory corruption from double-cancel

High **API-085** P2 - High Status: Open

[API-085] Passenger self-confirms own booking

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Business logic
Technique(s)	State transition testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. PUT /bookings/9a9e8419-4f11-42cf-bff5-a406f01f2fb6/status confirmed (passenger)

EXPECTED RESULT (ORACLE)

Only driver should confirm bookings

ACTUAL RESULT (PROOF)


```
{"success": true, "message": "Booking updated successfully", "data": {"booking": {"id": "9a9e8419-4f11-42cf-bff5-a406f01f2fb6", "rideId": "c6b6ff08-6fad-4b27-8183-3fb2e8e80f6b", "passengerId": "d8424298-1bb3-490b-84f8-bfb5d878da33", "seatsBooked": 1, "pickupPoint": "C", "status": "confirmed", "paymentStatus": "pending", "amountPaid": 130, "createdAt": "2026-10-08T10:12:41.689Z", "updatedAt": "2026-10-08T10:12:41.716Z", "ride": {"id": "c6b6ff08-6fad-4b27-8183-3fb2e8e80f6b", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName": "ConfirmRide", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "ConfirmDest", "departureTime": "2026-10-10T10:12:41.661Z", "availableSeats": 2, "pricePerSeat": 130, "isRecurring": false, "recurringDays": null, "status": "active", "vehicleType": "Car", "vehicleMake": null, "licensePlate": null, "hasAC": true, "notes": "QA test ride", "createdAt": "2026-10-08T10:12:41.666Z", "updatedAt": "2026-10-08T10:12:41.698Z"}}}}
```


SCREENSHOTS



ðŸ", 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

If passenger can self-confirm, approval workflow is broken

High **API-091** P2 - High Status: Open

[API-091] Review rating bounds unvalidated (latent) - rating=99 rejected only by workflow gate

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Security testing (XSS)
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /reviews comment=<img onerror>

EXPECTED RESULT (ORACLE)

Comment must be safely stored/encoded

ACTUAL RESULT (PROOF)

```
{"success": false, "message": "Can only review completed rides"}
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

High **API-095** P2 - High Status: Open

[API-095] Payment gateway fully simulated — no real JazzCash/EasyPaisa/bank

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional / Payment
Technique(s)	Functional testing / code review
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. paymentController.createPayment always creates completed payment with generated TXN

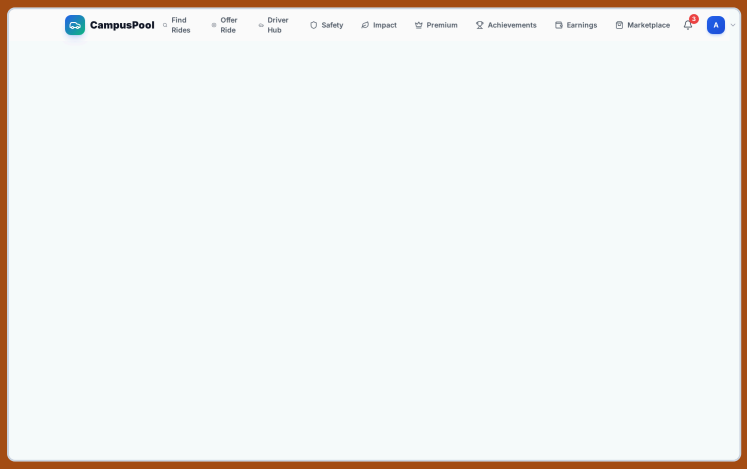
EXPECTED RESULT (ORACLE)

Real payment provider integration, or clearly marked sandbox with user warnings.

ACTUAL RESULT (PROOF)

```
paymentController.createPayment always creates completed payment with generated TXN id; UI shows
payment success  users believe money moved.
```

SCREENSHOTS



ðŸ", 14g_payment.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

False payment confirmation is a critical business defect

High **CR-01** P2 - High Status: Open

[CR-01] Hardcoded JWT secrets committed to repository

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Static analysis / code review
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. ecosystem.config.js, backend/.env, .env - JWT_SECRET hardcoded in repo

EXPECTED RESULT (ORACLE)

Secrets must live in env vars / secret manager, never in git

ACTUAL RESULT (PROOF)

```
Secrets present in source control and deploy configs
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Anyone with repo access can forge valid JWTs for any user id.

High **CR-09** P2 - High Status: Open

[CR-09] Sanitize middleware stores HTML-encoded data (double-encoding)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Security testing / input validation
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /auth/register fullName=<script>alert('xss')</script>

EXPECTED RESULT (ORACLE)

Output encoding belongs at render time; storing encoded data corrupts content

ACTUAL RESULT (PROOF)

```
sanitize middleware HTML-encodes and stores encoded entities in DB
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Users see literal <script> in profiles/messages; double-encoding bug class.

High **CR-12** P2 - High Status: Open

[CR-12] JWT in localStorage with no server-side revocation

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Code review / session management
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. frontend AuthContext stores JWT in localStorage; logout only clears client

EXPECTED RESULT (ORACLE)

Logout should invalidate session server-side

ACTUAL RESULT (PROOF)

```
No server-side token blacklist/revoke; 7-day expiry
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Stolen token remains valid up to 7 days after logout.

High **UI-006** P2 - High Status: Open

[UI-006] Search free-text filter ignored — unrelated rides returned

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Functional / search testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Search From=Lahore To=Islamabad

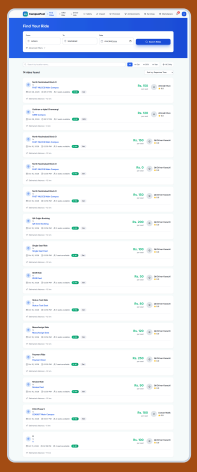
EXPECTED RESULT (ORACLE)

Users trust filter; wrong results cause incorrect bookings

ACTUAL RESULT (PROOF)

```
Karachi rides still displayed; API ignores free-text
```

SCREENSHOTS



ðŸ"¸ 11_search_lahore_islamabad.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

High **UI-007** P2 - High Status: Open

[UI-007] Ride details exposes driver phone publicly

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security / Privacy
Technique(s)	Privacy testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open ride details unauthenticated

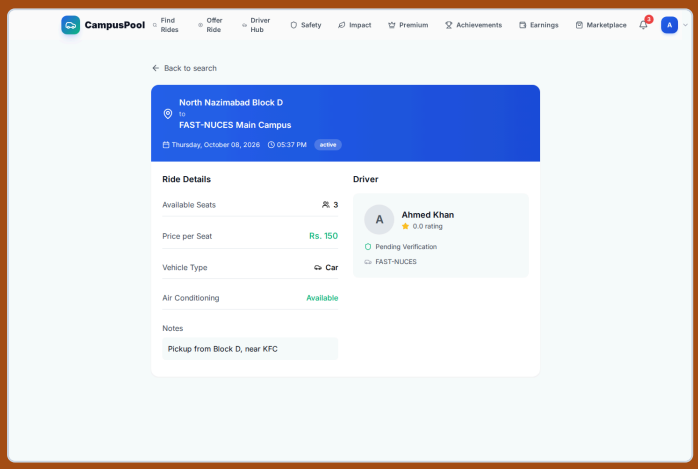
EXPECTED RESULT (ORACLE)

Public pages must not expose personal contact details

ACTUAL RESULT (PROOF)

```
Phone visible in UI and API
```

SCREENSHOTS



ðŸ"¸ 12_ride_details.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

High **UI-015** P2 - High Status: Open

[UI-015] Student verification fake — hardcoded CNIC / no real check

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security / Functional
Technique(s)	Functional / security testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open profile as demo user, inspect Verify control

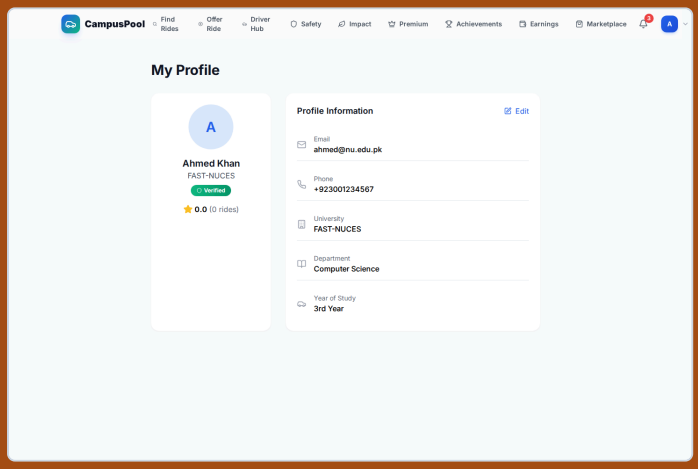
EXPECTED RESULT (ORACLE)

Anyone can self-declare verified student status platform trust undermined

ACTUAL RESULT (PROOF)

```
hardcoded CNIC in DOM=False; verify button=False; backend /auth/verify sets isVerified=true with no checks
```

SCREENSHOTS



ðŸ"¸ 14_profile_page.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

High **UI-027** P2 - High Status: Open

[UI-027] Create Ride past date + 0 seats submit

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	UI / Validation
Technique(s)	Boundary value analysis
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Set past date, seats=0, submit

EXPECTED RESULT (ORACLE)

Past departures and 0 seats must be rejected in UI

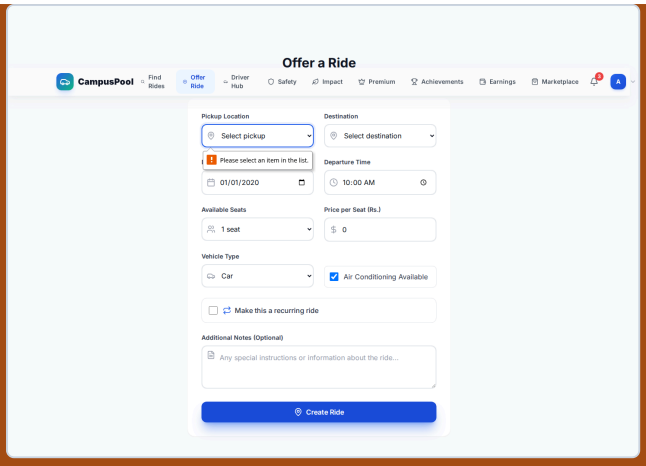
ACTUAL RESULT (PROOF)

```
url=https://carpool.33.jugaar.ai/create-ride text=CampusPool
Find Rides
Offer Ride
Driver Hub
Safety
Impact
Premium
Achievements
Earnings
Marketplace
3
A
Offer a Ride

Share your journey and split fuel costs

Pickup Location
Select pickup
North Nazimabad
Gulshan-e-Iqbal
Federal B Area
Malir
Korangi
```

SCREENSHOTS



ðŸ“¸ 14c4_create_ride_past_date.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-016** P3 - Medium Status: Open

[API-016] Create ride 0 seats - generic error message (validation hidden)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Validation
Technique(s)	Boundary value analysis
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /rides availableSeats=0

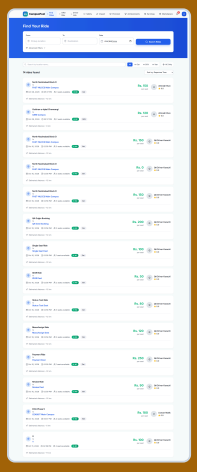
EXPECTED RESULT (ORACLE)

Model validate min:1 API must reject 0 seats

ACTUAL RESULT (PROOF)

```
{"success": false, "message": "Failed to create ride"}
```

SCREENSHOTS



ðŸ"¸ 15_console_errors_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-017** P3 - Medium Status: Open

[API-017] Create ride negative seats - generic error message

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Validation
Technique(s)	Boundary value analysis
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /rides availableSeats=-5

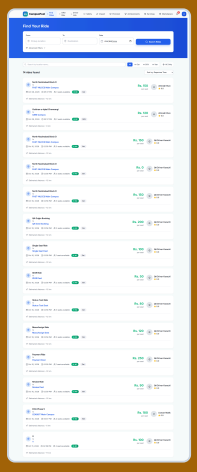
EXPECTED RESULT (ORACLE)

Negative seat count must be rejected

ACTUAL RESULT (PROOF)

```
{"success": false, "message": "Failed to create ride"}
```

SCREENSHOTS



ðŸ"¸ 15_console_errors_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-018** P3 - Medium Status: Open

[API-018] Create ride negative price - generic error message

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Validation
Technique(s)	Boundary value analysis
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /rides pricePerSeat=-100

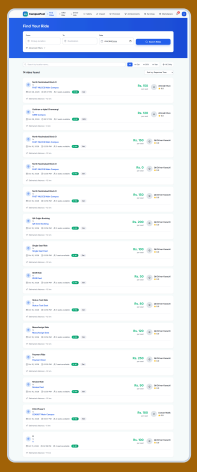
EXPECTED RESULT (ORACLE)

Negative fare must be rejected; amountPaid would go negative

ACTUAL RESULT (PROOF)

```
{"success": false, "message": "Failed to create ride"}
```

SCREENSHOTS



ðŸ"¸ 15_console_errors_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-019** P3 - Medium Status: Open

[API-019] Create ride with 0 price

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Validation
Technique(s)	Boundary value analysis
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /rides pricePerSeat=0

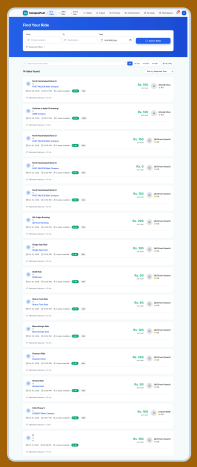
EXPECTED RESULT (ORACLE)

0 fare should be intentional/validated

ACTUAL RESULT (PROOF)


```
{"success": true, "message": "Ride created successfully", "data": {"ride": {"id": "158193df-7c59-4663-9626-6e40098bedb7", "status": "active", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName": "North Nazimabad Block D", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "FAST-NUCES Main Campus", "departureTime": "2026-10-10T09:58:06.472Z", "availableSeats": 3, "pricePerSeat": 0, "isRecurring": false, "vehicleType": "Car", "hasAC": true, "notes": "QA test ride", "updatedAt": "2026-10-08T09:58:06.481Z", "createdAt": "2026-10-08T09:58:06.481Z"}}}
```


SCREENSHOTS



ðŸ"¸ 15_console_errors_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-021** P3 - Medium Status: Open

[API-021] Create ride seats>7 - generic error message

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Validation
Technique(s)	Boundary value analysis
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /rides availableSeats=100

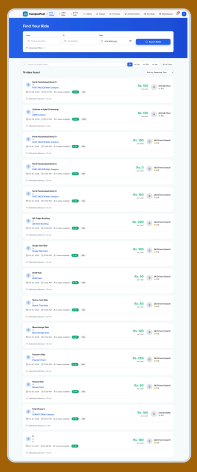
EXPECTED RESULT (ORACLE)

Model max is 7; exceeding max should be rejected

ACTUAL RESULT (PROOF)

```
{"success": false, "message": "Failed to create ride"}
```

SCREENSHOTS



ðŸ"¸ 15_console_errors_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-024** P3 - Medium Status: Open

[API-024] Search by free-text origin/destination ignored — returns unrelated rides

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Functional / search testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. GET /rides/search?originName=TotallyFakePlaceXYZ (returned 7 rides)

EXPECTED RESULT (ORACLE)

UI implies text search; API only supports lat/lng silent wrong results confuse users

ACTUAL RESULT (PROOF)


```
{"success": true, "data": {"rides": [{"id": "8a788b84-2cb5-4bd4-8b8d-9c39577d1e83", "driverId":
"19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "originLat": 24.9206, "originLng": 67.0655, "originName":
"North Nazimabad Block D", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName":
"FAST-NUCES Main Campus", "departureTime": "2026-10-08T12:37:28.598Z", "availableSeats": 3,
"pricePerSeat": 150, "isRecurring": false, "recurringDays": null, "status": "active", "vehicleType":
"Car", "vehicleMake": null, "licensePlate": null, "hasAC": true, "notes": "Pickup from Block D, near
KFC", "createdAt": "2026-10-07T12:37:28.599Z", "updatedAt": "2026-10-07T12:37:28.599Z", "driver":
{"id": "19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "fullName": "Ahmed Khan", "university": "FAST-NUCES",
"rating": 0, "profilePhoto": null}}, {"id": "44c8c995-0f8e-4d03-ae97-3d7276992a10", "driverId":
"19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "originLat": 24.8607, "originLng": 67.0011, "originName":
"Gulshan-e-Iqbal Chowrangi", "destinationLat": 24.8924, "destinationLng": 67.0724,
"destinationName": "IoBM Campus", "d â€¦(full transcript in Findings CSV)
```


SCREENSHOTS



ðŸ“¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-026** P3 - Medium Status: Open

[API-026] Search limit=999999 resource abuse

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Performance / API
Technique(s)	Performance / API testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. GET /rides/search?limit=999999

EXPECTED RESULT (ORACLE)

Limit must be clamped to a sane max to prevent DoS

ACTUAL RESULT (PROOF)


```
{"success": true, "data": {"rides": [{"id": "8a788b84-2cb5-4bd4-8b8d-9c39577d1e83", "driverId":
"19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "originLat": 24.9206, "originLng": 67.0655, "originName":
"North Nazimabad Block D", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName":
"FAST-NUCES Main Campus", "departureTime": "2026-10-08T12:37:28.598Z", "availableSeats": 3,
"pricePerSeat": 150, "isRecurring": false, "recurringDays": null, "status": "active", "vehicleType":
"Car", "vehicleMake": null, "licensePlate": null, "hasAC": true, "notes": "Pickup from Block D, near
KFC", "createdAt": "2026-10-07T12:37:28.599Z", "updatedAt": "2026-10-07T12:37:28.599Z", "driver":
{"id": "19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "fullName": "Ahmed Khan", "university": "FAST-NUCES",
"rating": 0, "profilePhoto": null}}, {"id": "44c8c995-0f8e-4d03-ae97-3d7276992a10", "driverId":
"19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "originLat": 24.8607, "originLng": 67.0011, "originName":
"Gulshan-e-Iqbal Chowrangi", "destinationLat": 24.8924, "destinationLng": 67.0724,
"destinationName": "IoBM Campus", "d â€¦(full transcript in Findings CSV)
```


SCREENSHOTS



ðŸ“¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-029** P3 - Medium Status: Open

[API-029] Book ride 0 seats - generic Failed to create booking message

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Business logic
Technique(s)	Boundary value analysis / business rules
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /bookings seatsBooked=0

EXPECTED RESULT (ORACLE)

0 seats must be rejected; creates bogus zero-amount booking

ACTUAL RESULT (PROOF)

```
{"success": false, "message": "Failed to create booking"}
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-031** P3 - Medium Status: Open

[API-031] Book ride negative seats - generic error message (validation hidden)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Business logic
Technique(s)	Boundary value analysis / business rules
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /bookings seatsBooked=-2

EXPECTED RESULT (ORACLE)

Negative seats must be rejected; availableSeats - (-2) INCREASES seats

ACTUAL RESULT (PROOF)

```
{"success": false, "message": "Failed to create booking"}
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-038** P3 - Medium Status: Open

[API-038] Booking creation fails with opaque generic errors

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Business logic
Technique(s)	State transition testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /bookings x2 on db5d12b7-48bd-4a0b-b495-402944f882f3

EXPECTED RESULT (ORACLE)

Second booking must be rejected if already booked

ACTUAL RESULT (PROOF)

```
first={'success': False, 'message': 'Failed to create booking'} | second={'success': False, 'message': 'Failed to create booking'}
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-050** P3 - Medium Status: Open

[API-050] Payment with unlisted method accepted

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Validation
Technique(s)	Equivalence partitioning
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /payments method=CryptoBitcoin

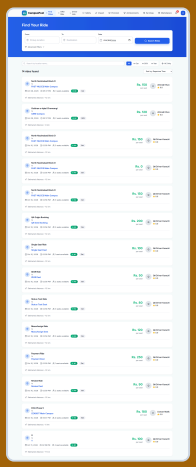
EXPECTED RESULT (ORACLE)

Method must be constrained to JazzCash/EasyPaisa/Bank/Cash

ACTUAL RESULT (PROOF)


```
{"success": true, "message": "Payment successful", "data": {"payment": {"id": "6fda7581-4e6a-4f6f-8c3b-c32a4f02572b", "bookingId": "e06ca810-f61f-44f7-8ca0-5b2451f7a89a", "payerId": "d8424298-1bb3-490b-84f8-bfb5d878da33", "amount": 250, "method": "CryptoBitcoin", "transactionId": "TXN_1791453561966_i0qrkzz8j", "status": "completed", "updatedAt": "2026-10-08T09:59:21.967Z", "createdAt": "2026-10-08T09:59:21.967Z"}}}
```


SCREENSHOTS



ðŸ"¸ 15_console_errors_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-060** P3 - Medium Status: Open

[API-060] Send empty message content

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Validation
Technique(s)	Equivalence partitioning
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /messages content=''

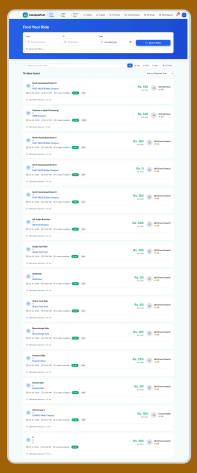
EXPECTED RESULT (ORACLE)

Empty messages must be rejected

ACTUAL RESULT (PROOF)


```
{"success": true, "message": "Message sent successfully", "data": {"message": {"id": "85554878-fa7e-447a-90f9-1b191cb477ab", "isRead": false, "senderId": "d8424298-1bb3-490b-84f8-bfb5d878da33", "receiverId": "19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "content": "", "updatedAt": "2026-10-08T09:59:22.296Z", "createdAt": "2026-10-08T09:59:22.296Z"}}}
```


SCREENSHOTS



ðŸ"¸ 15_console_errors_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-065** P3 - Medium Status: Open

[API-065] Fetch other user's profile by ID (PII exposure)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Privacy / IDOR testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. GET /users/profile/19b3d7ed-bc44-4ab4-93c9-412650d73a3d

EXPECTED RESULT (ORACLE)

Public profiles must not expose phone/email without consent rules

ACTUAL RESULT (PROOF)


```
{"success": true, "data": {"id": "19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "email": "ahmed@nu.edu.pk",
"fullName": "Ahmed Khan", "phone": "+923001234567", "university": "FAST-NUCES", "department":
"Computer Science", "yearOfStudy": "3rd Year", "isVerified": true, "isDriver": true, "rating": 0,
"totalRides": 0, "createdAt": "2026-10-07T12:37:28.182Z", "reviews": [], "completedRides": 0}}
```


SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-076** P3 - Medium Status: Open

[API-076] Profile update attempts email change (ignored silently)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Functional testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. PUT /auth/profile email=hacked@evil.com

EXPECTED RESULT (ORACLE)

If email not updatable, API should say so; silent ignore misleads

ACTUAL RESULT (PROOF)

```
Success but email unchanged
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Backend ignores email field

Medium **API-077** P3 - Medium Status: Open

[API-077] Profile update attempts password change via profile (ignored)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Functional testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. PUT /auth/profile password=NewPass@999

EXPECTED RESULT (ORACLE)

Password change must use dedicated endpoint or be rejected clearly

ACTUAL RESULT (PROOF)

```
Success but password unchanged
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Password silently ignored no password change endpoint exists

Medium **API-079** P3 - Medium Status: Open

[API-079] Profile update invalid phone

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Validation
Technique(s)	Boundary value analysis
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. PUT /auth/profile phone='not-a-phone'

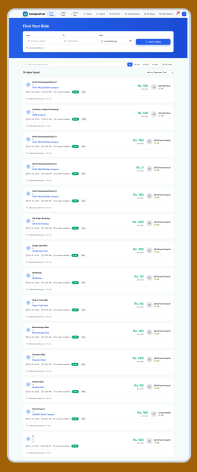
EXPECTED RESULT (ORACLE)

Invalid phone must be rejected with clear message

ACTUAL RESULT (PROOF)

```
Failed to update profile
```

SCREENSHOTS



ðŸ"¸ 15_console_errors_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Model validation triggers generic 500-style message

Medium **API-087** P3 - Medium Status: Open

[API-087] Driver marks booking completed while ride still active

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Business logic
Technique(s)	State transition testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. PUT /bookings/9a9e8419-4f11-42cf-bff5-a406f01f2fb6/status completed (ride active)

EXPECTED RESULT (ORACLE)

Completed status should require ride completion workflow

ACTUAL RESULT (PROOF)


```
{"success": true, "message": "Booking updated successfully", "data": {"booking": {"id": "9a9e8419-4f11-42cf-bff5-a406f01f2fb6", "rideId": "c6b6ff08-6fad-4b27-8183-3fb2e8e80f6b", "passengerId": "d8424298-1bb3-490b-84f8-bfb5d878da33", "seatsBooked": 1, "pickupPoint": "C", "status": "completed", "paymentStatus": "pending", "amountPaid": 130, "createdAt": "2026-10-08T10:12:41.689Z", "updatedAt": "2026-10-08T10:12:41.749Z", "ride": {"id": "c6b6ff08-6fad-4b27-8183-3fb2e8e80f6b", "driverId": "1a66017f-f150-48f3-91cb-1a2b106fa94b", "originLat": 24.9206, "originLng": 67.0655, "originName": "ConfirmRide", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName": "ConfirmDest", "departureTime": "2026-10-10T10:12:41.661Z", "availableSeats": 2, "pricePerSeat": 130, "isRecurring": false, "recurringDays": null, "status": "active", "vehicleType": "Car", "vehicleMake": null, "licensePlate": null, "hasAC": true, "notes": "QA test ride", "createdAt": "2026-10-08T10:12:41.666Z", "updatedAt": "2026-10-08T10:12:41.698Z"}}}}
```


SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Workflow bypass possible

Medium **API-089** P3 - Medium Status: Open

[API-089] Duplicate review prevention not reachable/unverified

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Business logic
Technique(s)	State transition testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /reviews same ride twice

EXPECTED RESULT (ORACLE)

Only one review per passenger per ride allowed

ACTUAL RESULT (PROOF)

```
{"success": false, "message": "Can only review completed rides"}
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-090** P3 - Medium Status: Open

[API-090] Review rating bounds unvalidated when review path opens

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Validation
Technique(s)	Boundary value analysis
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. POST /reviews rating=99 after valid booking

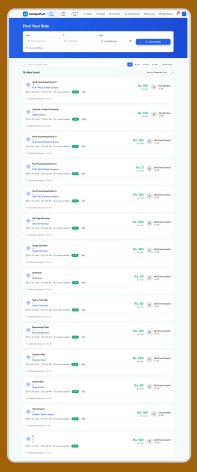
EXPECTED RESULT (ORACLE)

Rating must be constrained 1-5 even after booking check passes

ACTUAL RESULT (PROOF)

```
{"success": false, "message": "Can only review completed rides"}
```

SCREENSHOTS



ðŸ"¸ 15_console_errors_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **API-093** P3 - Medium Status: Open

[API-093] User search endpoint broken

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	API / Functional
Technique(s)	API testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. GET /users/search?q=a

EXPECTED RESULT (ORACLE)

Search must return results or clear empty state

ACTUAL RESULT (PROOF)

```
{"success": false, "message": "Failed to search users"}
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Broken user search endpoint

Medium **API-097** P3 - Medium Status: Open

[API-097] CORS allowlist includes raw IP origins (67.215.237.229)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	CORS testing / code review
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. backend/src/index.ts CORS origin array

EXPECTED RESULT (ORACLE)

Only production HTTPS domain + explicit localhost dev origins in CORS allowlist.

ACTUAL RESULT (PROOF)

```
CORS allowlist includes raw IP origins 67.215.237.229 and 67.215.237.229:3456.
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Config hygiene issue

Medium **API-098** P3 - Medium Status: Open

[API-098] JWT expiry 7 days + localStorage + no server revoke

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Session management / code review
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. backend/src/utils/helpers.ts generateToken; frontend AuthContext localStorage

EXPECTED RESULT (ORACLE)

Shorter JWT expiry, refresh tokens, server-side revoke on logout.

ACTUAL RESULT (PROOF)

```
7-day JWT stored in localStorage; logout only clears client; no server-side revocation.
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Long-lived tokens in localStorage increase theft risk

Medium **API-099** P3 - Medium Status: Open

[API-099] Forgot password feature completely missing (UI link dead + no API)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Functional / navigation testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Login page Forgot password link; no /auth/forgot or reset endpoint in backend routes

EXPECTED RESULT (ORACLE)

Full password reset flow (email token or OTP) with backend endpoint.

ACTUAL RESULT (PROOF)

```
Forgot password is UI-only dead link; no /auth/forgot or reset endpoint exists in backend routes.
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Account recovery impossible users locked out forever

Medium **CR-02** P3 - Medium Status: Open

[CR-02] No admin/moderation pages despite feature claims

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Exploratory / feature completeness
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. frontend/src/pages/admin/ directory is empty

EXPECTED RESULT (ORACLE)

README/UI claims moderation; empty folder = unimplemented feature

ACTUAL RESULT (PROOF)

```
No admin UI routes or components exist
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Reported users have no admin handling path.

Medium **CR-03** P3 - Medium Status: Open

[CR-03] Recurring rides stored but never expanded into actual rides

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Business rules / code review
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Create ride with isRecurring=true + recurringDays Mon-Fri

EXPECTED RESULT (ORACLE)

Recurring option must generate concrete future rides or be removed from UI

ACTUAL RESULT (PROOF)

```
recurringDays saved on ride; no scheduler creates future instances
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Misleading feature for daily commuters.

Medium **CR-04** P3 - Medium Status: Open

[CR-04] No automated test suite in repository

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	QA Process
Technique(s)	Static analysis / process review
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Search for *.test.* / jest / playwright / cypress config

EXPECTED RESULT (ORACLE)

Production apps need regression tests for booking/auth/payment flows

ACTUAL RESULT (PROOF)

```
No test files or test runner config outside node_modules
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

QA process gap increases defect escape risk.

Medium **CR-05** P3 - Medium Status: Open

[CR-05] Broken deploy configs (Procfile / render.yaml)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Reliability
Technique(s)	Static analysis / deployment review
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Procfile web:npm start; render.yaml builds at repo root

EXPECTED RESULT (ORACLE)

Deploy manifests must match project layout

ACTUAL RESULT (PROOF)

```
Root has no package.json - deploy commands cannot work as written
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Render/Heroku paths in docs are incorrect.

Medium **CR-07** P3 - Medium Status: Open

[CR-07] Demo credentials printed by start.sh in cleartext

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Security review / information disclosure
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. ./start.sh prints demo account emails/passwords to console

EXPECTED RESULT (ORACLE)

Demo creds must not be advertised on production hosts

ACTUAL RESULT (PROOF)

```
ahmed@nu.edu.pk / test123 etc. displayed on server start logs
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Weak password test123 + reseed on restart = account takeover risk.

Medium **CR-08** P3 - Medium Status: Open

[CR-08] No email verification / SMTP integration

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Feature completeness / code review
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Search backend for nodemailer/verify-email flows

EXPECTED RESULT (ORACLE)

Registration trust requires real email verification

ACTUAL RESULT (PROOF)

```
No mailer code; README claims email verification
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Fake trust signal for a student-only platform.

Medium **CR-10** P3 - Medium Status: Open

[CR-10] Generic error messages hide field-level validation failures

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Reliability
Technique(s)	Code review / error handling
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Booking/ride create with invalid fields returns generic Failed to create ...

EXPECTED RESULT (ORACLE)

API should return 400 with field-level validation errors

ACTUAL RESULT (PROOF)

```
Controller catch blocks swallow Sequelize validation messages
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Users cannot tell which field is invalid.

Medium **CR-11** P3 - Medium Status: Open

[CR-11] User search API endpoint broken

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Code review / data model
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. GET /api/users/search?q=a

EXPECTED RESULT (ORACLE)

Search must return results or explicit empty state

ACTUAL RESULT (PROOF)

```
Endpoint returns Failed to search users
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Broken public API surface.

Medium **CR-13** P3 - Medium Status: Open

[CR-13] DataTypes.ARRAY may break on SQLite dialect

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Compatibility
Technique(s)	Code review / data model
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Ride.recurringDays uses DataTypes.ARRAY

EXPECTED RESULT (ORACLE)

DB portability must be tested for chosen ORM types

ACTUAL RESULT (PROOF)

```
SQLite does not support ARRAY type the same way as Postgres
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Potential SQLite/Postgres dialect bugs in prod migration.

Medium **CR-14** P3 - Medium Status: Open

[CR-14] Seat booking race condition (no transaction/atomic decrement)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Performance
Technique(s)	Code review / concurrency
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. createBooking reads availableSeats then updates without transaction/lock

EXPECTED RESULT (ORACLE)

Seat decrement must use atomic UPDATE ... WHERE availableSeats >= n

ACTUAL RESULT (PROOF)

```
Concurrent bookings can oversell seats (race condition)
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Classic inventory race condition under load.

Medium **CR-16** P3 - Medium Status: Open

[CR-16] Public ride detail exposes driver phone

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Code review / authz
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. GET /api/rides/:id includes driver phone without authentication

EXPECTED RESULT (ORACLE)

PII should be hidden until mutual booking

ACTUAL RESULT (PROOF)

```
Public ride detail returns phone in driver object
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Privacy defect on public endpoint.

Medium **CR-17** P3 - Medium Status: Open

[CR-17] Profile update silently ignores empty/fullName edge cases

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Code review / UX
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Profile update fullName uses fullName || user.fullName

EXPECTED RESULT (ORACLE)

Update API should validate and apply explicit field updates

ACTUAL RESULT (PROOF)

```
Cannot clear optional fields; empty string silently ignored
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Silent no-op confuses users editing profile.

Medium **CR-19** P3 - Medium Status: Open

[CR-19] Rate limiting missing on reviews/messages/safety/impact/users

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Security
Technique(s)	Security review / rate limiting
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. express-rate-limit only on auth/rides/bookings/payments

EXPECTED RESULT (ORACLE)

All public API routes should be rate limited

ACTUAL RESULT (PROOF)

```
reviews/messages/safety/impact/users routes unthrottled
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Spam/abuse vector on unprotected endpoints.

Medium **CR-20** P3 - Medium Status: Open

[CR-20] Impact/Emergency/PublicProfile pages use mock data only

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Code review / UI
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. ImpactDashboard, EmergencySOS, PublicProfile pages

EXPECTED RESULT (ORACLE)

UI features must wire to backend APIs

ACTUAL RESULT (PROOF)

```
Pages use local mock state; do not call /api/impact or /api/safety
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Dead-end features that look functional.

Medium UI-001 P3 - Medium Status: Open

[UI-001] 'Forgot password' dead link

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Usability
Technique(s)	Navigation / dead-link testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Click Forgot password on login

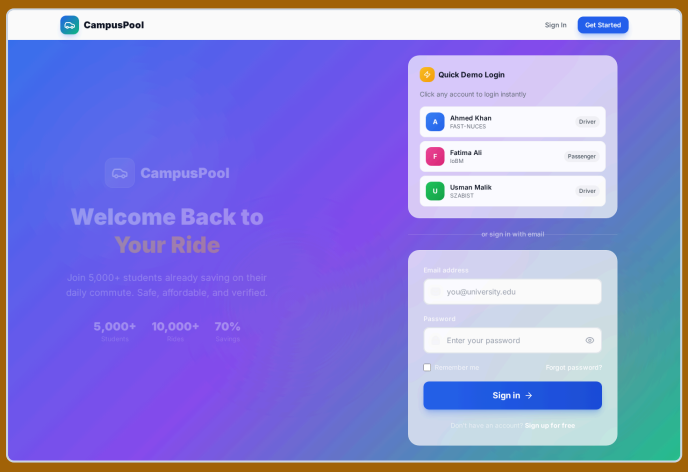
EXPECTED RESULT (ORACLE)

Password recovery is mandatory; dead link blocks account recovery

ACTUAL RESULT (PROOF)

```
href=no-href or no route
```

SCREENSHOTS



ðŸ"¸ 07_forgot_password.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-008** P3 - Medium Status: Open

[UI-008] Premium page — mock/hardcoded data (no real API)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Exploratory / functional testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open /premium

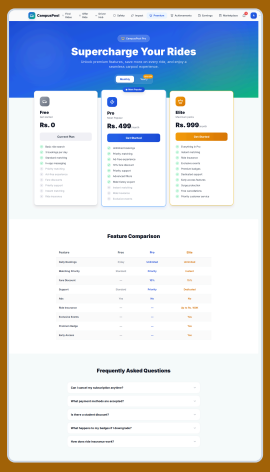
EXPECTED RESULT (ORACLE)

Feature presented but not backed by working backend

ACTUAL RESULT (PROOF)

```
Hardcoded plans/pricing
```

SCREENSHOTS



ðŸ"¸ mock_premium.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-009** P3 - Medium Status: Open

[UI-009] Earnings page — mock/hardcoded data (no real API)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Exploratory / functional testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open /earnings

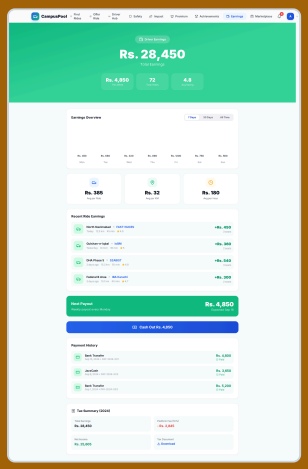
EXPECTED RESULT (ORACLE)

Fake feature

ACTUAL RESULT (PROOF)

```
Hardcoded earnings totals
```

SCREENSHOTS



ðŸ"¸ mock_earnings.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-010** P3 - Medium Status: Open

[UI-010] Achievements page — mock/hardcoded data (no real API)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Exploratory / functional testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open /achievements

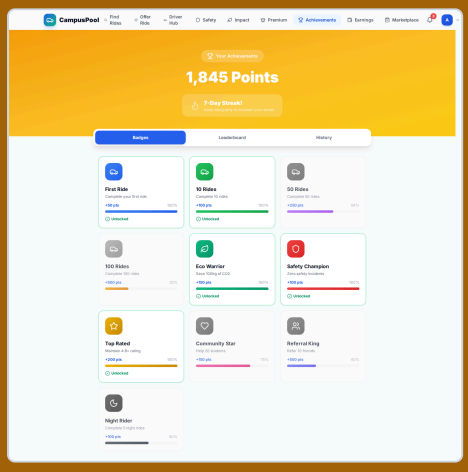
EXPECTED RESULT (ORACLE)

Fake feature

ACTUAL RESULT (PROOF)

```
Hardcoded badges/leaderboards
```

SCREENSHOTS



ðŸ"¸ mock_achievements.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-011** P3 - Medium Status: Open

[UI-011] Smart Match page — mock/hardcoded data (no real API)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Exploratory / functional testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open /smart-match

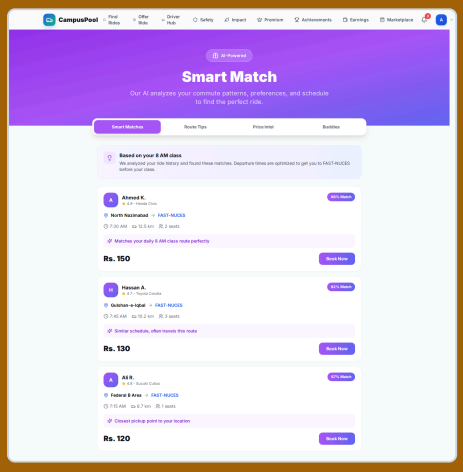
EXPECTED RESULT (ORACLE)

Fake feature

ACTUAL RESULT (PROOF)

```
Fake AI matches
```

SCREENSHOTS



ðŸ"¸ mock_smart_match.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-012** P3 - Medium Status: Open

[UI-012] Marketplace page — mock/hardcoded data (no real API)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Exploratory / functional testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open /marketplace

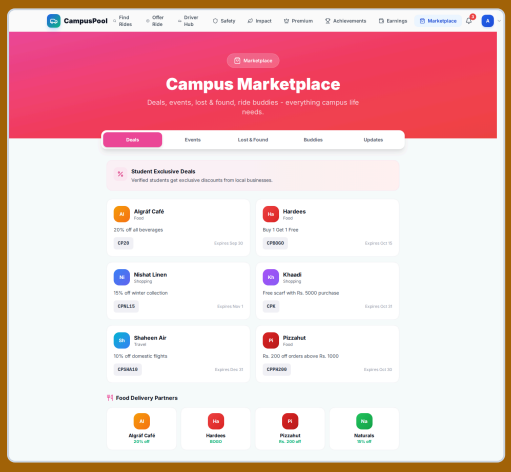
EXPECTED RESULT (ORACLE)

Fake feature

ACTUAL RESULT (PROOF)

```
Hardcoded deals
```

SCREENSHOTS



ðŸ"¸ mock_marketplace.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-013** P3 - Medium Status: Open

[UI-013] Sponsored page — mock/hardcoded data (no real API)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Exploratory / functional testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open /sponsored

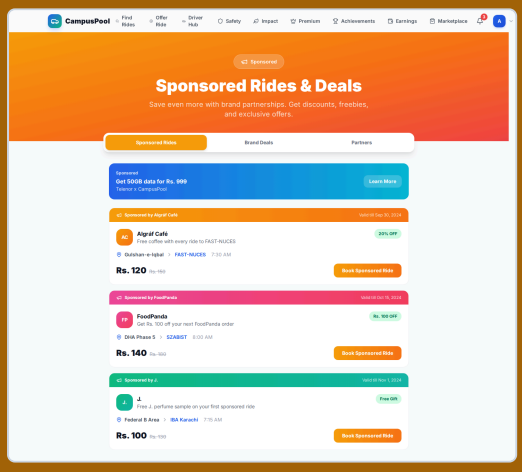
EXPECTED RESULT (ORACLE)

Fake feature

ACTUAL RESULT (PROOF)

```
Hardcoded sponsorships
```

SCREENSHOTS



ðŸ"¸ mock_sponsored.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-014** P3 - Medium Status: Open

[UI-014] Cities page — mock/hardcoded data (no real API)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Functional
Technique(s)	Exploratory / functional testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open /cities

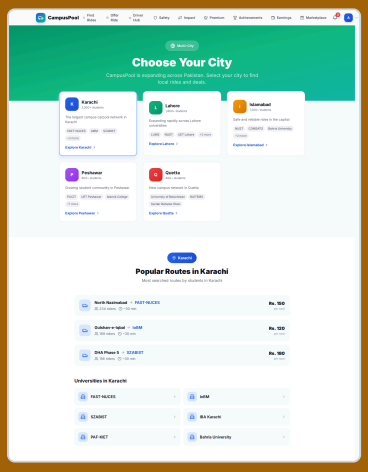
EXPECTED RESULT (ORACLE)

Fake feature

ACTUAL RESULT (PROOF)

```
Hardcoded city stats
```

SCREENSHOTS



ðŸ"¸ mock_cities.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-026** P3 - Medium Status: Open

[UI-026] Create Ride empty submit validation

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	UI / Validation
Technique(s)	Form validation testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open /create-ride, submit empty

EXPECTED RESULT (ORACLE)

Form validation UX

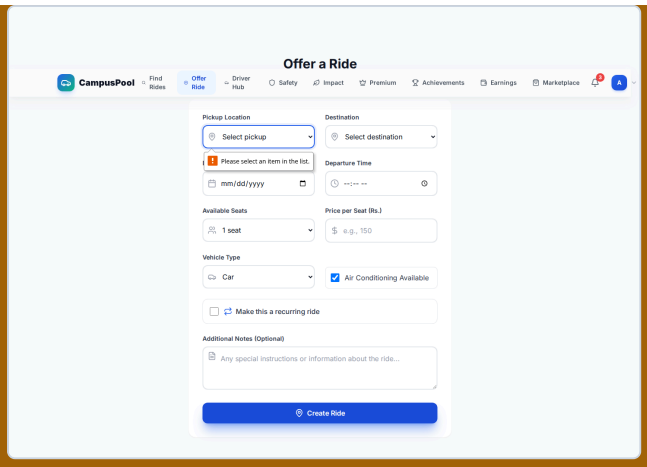
ACTUAL RESULT (PROOF)

```
text=CampusPool
Find Rides
Offer Ride
Driver Hub
Safety
Impact
Premium
Achievements
Earnings
Marketplace
3
A
Offer a Ride

Share your journey and split fuel costs

Pickup Location
Select pickup
North Nazimabad
Gulshan-e-Iqbal
Federal B Area
Malir
Korangi
```

SCREENSHOTS



ðŸ“¸ 14c3_create_ride_empty_submit.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-028** P3 - Medium Status: Open

[UI-028] Responsive iphone_se 375x667 horizontal overflow

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Responsiveness / Compatibility
Technique(s)	Responsive design testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open home at 375x667

EXPECTED RESULT (ORACLE)

Mobile users must not see cut-off content

ACTUAL RESULT (PROOF)

```
scrollW=401 clientW=375 overflow=True
```

SCREENSHOTS



ðŸ"¸ resp_iphone_se_home.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-029** P3 - Medium Status: Open

[UI-029] Responsive iphone_14 390x844 horizontal overflow

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Responsiveness / Compatibility
Technique(s)	Responsive design testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open home at 390x844

EXPECTED RESULT (ORACLE)

Mobile users must not see cut-off content

ACTUAL RESULT (PROOF)

```
scrollW=401 clientW=390 overflow=True
```

SCREENSHOTS



ðŸ"¸ resp_iphone_14_home.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-030** P3 - Medium Status: Open

[UI-030] Responsive galaxy_s 360x740 horizontal overflow

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Responsiveness / Compatibility
Technique(s)	Responsive design testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open home at 360x740

EXPECTED RESULT (ORACLE)

Mobile users must not see cut-off content

ACTUAL RESULT (PROOF)

```
scrollW=401 clientW=360 overflow=True
```

SCREENSHOTS



ðŸ"¸ resp_galaxy_s_home.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-032** P3 - Medium Status: Open

[UI-032] Responsive desktop_small 1024x768 horizontal overflow

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Responsiveness / Compatibility
Technique(s)	Responsive design testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open home at 1024x768

EXPECTED RESULT (ORACLE)

Mobile users must not see cut-off content

ACTUAL RESULT (PROOF)

```
scrollW=1381 clientW=1024 overflow=True
```

SCREENSHOTS



ðŸ"¸ resp_desktop_small_home.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-036** P3 - Medium Status: Open

[UI-036] Accessibility spot-check home

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Accessibility
Technique(s)	Accessibility testing (WCAG)
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Audit home page

EXPECTED RESULT (ORACLE)

WCAG 2.1 AA requires text alternatives and labels

ACTUAL RESULT (PROOF)

```
{'imgs': 0, 'missingAlt': 0, 'inputs': 0, 'unlabeled': 0, 'buttons': 3, 'emptyBtns': 2}
```

SCREENSHOTS



ðŸ"¸ 17_a11y_home.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Medium **UI-037** P3 - Medium Status: Open

[UI-037] Accessibility spot-check search

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Accessibility
Technique(s)	Accessibility testing (WCAG)
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Audit /search form labels

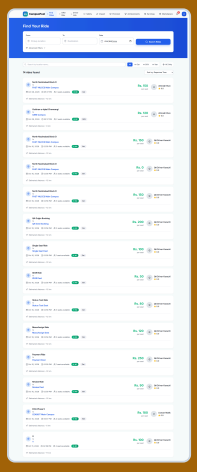
EXPECTED RESULT (ORACLE)

Labels required for assistive technology

ACTUAL RESULT (PROOF)

```
{'inputs': 5, 'unlabeled': 2}
```

SCREENSHOTS



ðŸ"¸ 17b_a11y_search.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Low **API-025** P4 - Low Status: Open

[API-025] Search minSeats=-10 unvalidated

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Validation
Technique(s)	Boundary value analysis
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. GET /rides/search?minSeats=-10

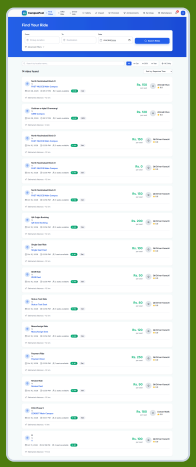
EXPECTED RESULT (ORACLE)

Negative minSeats should be rejected or ignored explicitly

ACTUAL RESULT (PROOF)


```
{"success": true, "data": {"rides": [{"id": "8a788b84-2cb5-4bd4-8b8d-9c39577d1e83", "driverId":
"19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "originLat": 24.9206, "originLng": 67.0655, "originName":
"North Nazimabad Block D", "destinationLat": 24.8157, "destinationLng": 67.0685, "destinationName":
"FAST-NUCES Main Campus", "departureTime": "2026-10-08T12:37:28.598Z", "availableSeats": 3,
"pricePerSeat": 150, "isRecurring": false, "recurringDays": null, "status": "active", "vehicleType":
"Car", "vehicleMake": null, "licensePlate": null, "hasAC": true, "notes": "Pickup from Block D, near
KFC", "createdAt": "2026-10-07T12:37:28.599Z", "updatedAt": "2026-10-07T12:37:28.599Z", "driver":
{"id": "19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "fullName": "Ahmed Khan", "university": "FAST-NUCES",
"rating": 0, "profilePhoto": null}}, {"id": "44c8c995-0f8e-4d03-ae97-3d7276992a10", "driverId":
"19b3d7ed-bc44-4ab4-93c9-412650d73a3d", "originLat": 24.8607, "originLng": 67.0011, "originName":
"Gulshan-e-Iqbal Chowrangi", "destinationLat": 24.8924, "destinationLng": 67.0724,
"destinationName": "IoBM Campus", "d â€¦(full transcript in Findings CSV)
```


SCREENSHOTS



ðŸ"¸ 15_console_errors_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Low **API-027** P4 - Low Status: Open

[API-027] Search with invalid departureDate

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Validation
Technique(s)	Equivalence partitioning
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. GET /rides/search?departureDate=not-a-date

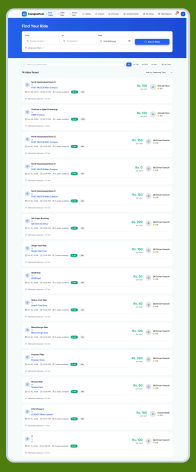
EXPECTED RESULT (ORACLE)

Invalid date should return 400, not silently ignore or 500

ACTUAL RESULT (PROOF)

```
{"success": true, "data": {"rides": [], "count": 0}}
```

SCREENSHOTS



ðŸ"¸ 15_console_errors_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Low **CR-06** P4 - Low Status: Open

[CR-06] PORT inconsistency (5000 vs 5001 defaults)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Configuration
Technique(s)	Configuration review
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. index.ts PORT default 5000; backend/.env PORT=5001; root .env PORT=5000

EXPECTED RESULT (ORACLE)

Single source of truth for ports prevents mis-routed traffic

ACTUAL RESULT (PROOF)

```
Multiple conflicting port defaults
```

SCREENSHOTS



ðŸ"¸ 01_home.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Local vs production confusion risk.

Low **CR-15** P4 - Low Status: Open

[CR-15] Real-time chat is polling only (30s interval)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Usability
Technique(s)	Code review / UX
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Navbar unread badge polls every 30s; no websockets

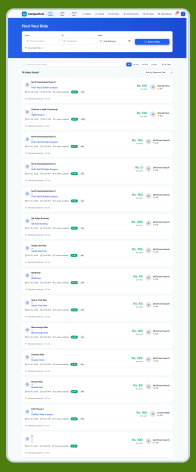
EXPECTED RESULT (ORACLE)

Real-time chat should use push/websocket

ACTUAL RESULT (PROOF)

```
Messages appear up to 30s late; README claims real-time chat
```

SCREENSHOTS



ðŸ"¸ 17b_a11y_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Feature marketed as real-time is polling-based.

Low **CR-18** P4 - Low Status: Open

[CR-18] README claims unimplemented features (notifications, maps, admin)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Usability
Technique(s)	Code review / documentation
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. README claims push notifications, maps, payment gateways, admin dashboard

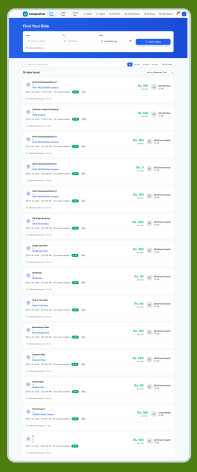
EXPECTED RESULT (ORACLE)

Documentation must match shipped functionality

ACTUAL RESULT (PROOF)

```
Multiple claimed features unimplemented
```

SCREENSHOTS



ðŸ"¸ 17b_a11y_search.png â€" representative evidence for this feature area; full sequential capture set lives in the repository's `evidence/screenshots` folder.

IMPACT

Stakeholder expectations set incorrectly.

Low UI-002 P4 - Low Status: Open

[UI-002] 'Remember me' checkbox cosmetic / non-functional

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Usability
Technique(s)	Usability testing
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Inspect Remember me on login

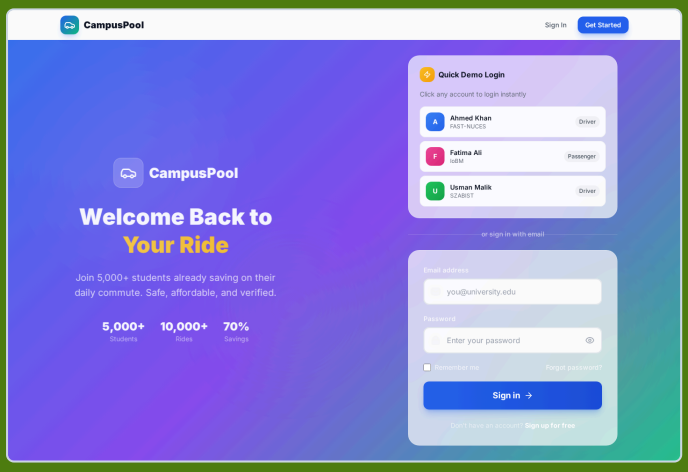
EXPECTED RESULT (ORACLE)

Misleading UI controls harm trust

ACTUAL RESULT (PROOF)

```
Present; AuthContext always stores token
```

SCREENSHOTS



ðŸ"¸ 06_login_page.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

Low **UI-035** P4 - Low Status: Open

[UI-035] Unknown route handling (404)

Application / URL	CampusPool â€" https://carpool.33.jugaar.ai
Category	Usability
Technique(s)	Navigation / error handling
Environment	Production URL Â· Chrome/Playwright Â· Windows 11 Â· 8 October 2026
Likelihood (impact)	Likely

REPRODUCIBLE STEPS

1. Open unknown URL

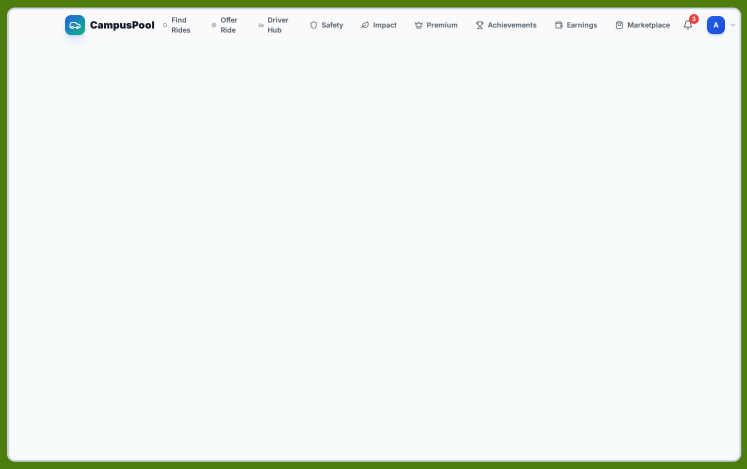
EXPECTED RESULT (ORACLE)

SPA must handle unknown routes

ACTUAL RESULT (PROOF)

```
is404=False text=CampusPool
Find Rides
Offer Ride
Driver Hub
Safety
Impact
Premium
Achievements
Earnings
Marketplace
3
A
```

SCREENSHOTS



ðŸ"¸ 16_custom_404.png â€" captured during this campaign.

IMPACT

Degraded functionality / quality risk documented in the defect dataset.

8 Â· Verification status & deferred items

Rating-path defects (API-090/091) cannot reproduce on the field *today* because the workflow gate (API-054/MF-06) blocks review creation; they are logged as **Possible** likelihood with a deferred-verification rule to execute once the unlock ships. Every other field defect is reproducible per its recorded steps.

9 Â· Remediation priorities (QC view)

9.1 Immediate (P1)

1. Disable `sequelize.sync({force:true})`; adopt migrations (API-094).
2. Transactional seat decrement + concurrency regression test (CR-14, API-084).
3. Label payments sandbox; remove fake success screen (API-095); enable refund execution (MF-13).
4. Enforce CNIC validation + document proof for verification (API-080/081, MF-05).
5. Rotate and purge committed credentials; add secret-scanning gate (CR-01).

9.2 Short-term (P2)

1. Ownership and state checks: no self-confirm (API-085), no own-ride booking, no mass-assignment writes (API-043/044).
2. PII masking + auth on ride detail; publish privacy policy (API-074/UI-006, MF-17).
3. Field-level validation errors instead of opaque messages (API-016..021, CR-10).
4. API guards: search caps/pagination (API-026), message content validation (API-060).
5. Driver-side cancel-with-bookings handling + passenger side-effects (API-047/048).

9.3 Mid-term (P3+)

- Ride/booking/payment state machines; recurring rides expansion (MF-15); automated test suite (CR-04); accessibility remediation (UI-036/037).
- Replace all mock pages with real APIs or explicit "preview" labelling.

10 Â· Sign-off

Role	Name / contact	Date	Signature / approval
QA/QC Author	Tehzeeb â€" tehzeebwaliya@gmail.com Â· 03169031194	8 October 2026	*electronic â€" submitted 8 October 2026*
Course Head	Hussain Saleem		

Prepared by: Tehzeeb (B23110106073) â€" University of Karachi â€" SQET/ST (Software Quality Engineering & Testing)
Contact: tehzeebwaliya@gmail.com | 03169031194 Â· **Evidence:** https://github.com/tehzeebshahs4s-hub/qc_report

Appendix A â€” Features List (application features tested)

The complete list of CampusPool features that define the test scope â€” everything the app promises, item by item.

Authentication & Accounts

- Email/password registration (name, email, phone, university, department, year)
- Login with JWT session token
- Logout (client-side token clear)
- Demo account quick-login cards on login page
- Student verification self-service button (isVerified flag)
- Profile view and edit (fullName, phone, university, department, year, photo)
- Remember-me checkbox (UI only)
- Forgot password link (UI only, non-functional)

Rides (Driver)

- Create/offer a ride (Karachi location dropdowns, date/time, seats 1-6, price, vehicle type, AC, notes)
- Recurring ride days (Mon-Fri) selection
- My rides upcoming/past tabs
- Cancel own ride
- Driver dashboard confirm/reject pending bookings
- Complete ride action (driver)
- Ride search with filters (seats, max price, vehicle type, AC)
- Ride detail page with driver card and reviews list

Bookings (Passenger)

- Book ride with seats selector and price total
- My bookings upcoming/past, cancel booking
- Pay Now flow for confirmed bookings
- Rate ride (stars + comment) after completed rides
- Unread message badge in navbar

Payments

- Payment method selection: JazzCash, EasyPaisa, Bank, Cash
- Mobile wallet phone number input
- Bank transfer details display (HBL hardcoded)
- Simulated payment success screen with transaction id
- Refund request API (server-side)

Messaging

- Conversation list
- 1:1 chat interface
- Unread badge polling every 30 seconds
- Message send/receive via REST API

Safety & Impact

- Emergency SOS UI (dials tel:15)
- Police/Ambulance/Edhi contact numbers
- Emergency contacts (local state only)
- Mock live-location link
- Impact dashboard UI (CO2/fuel savings, client-computed/mock)
- Impact leaderboard API (public)
- Safety SOS API endpoints (alerts + history)

Marketing / Mock Pages (not API-backed)

- Premium plans page (Free/Pro/Elite pricing UI)
- Earnings dashboard (hardcoded totals/charts)
- Achievements / gamification badges and leaderboards
- Smart Match (AI ride matching, mock)
- Marketplace (deals, events, lost & found, mock)
- Sponsored rides (brand deals, mock)
- City selector (5 Pakistani cities, mock stats)
- Home landing marketing page (fabricated stats)
- Public user profile page (mock/local)
- Admin pages (empty directory, unimplemented)

Search & Discovery

- Ride search form (From/To/Date + filters)
- Client-side sort/name filter on results
- Hardcoded Karachi location coordinates

Non-functional features claimed or observed

- HTTPS via Caddy reverse proxy with HSTS
- Security headers partially set (HSTS, nosniff, Referrer-Policy)
- Helmet middleware on API (CSP on API responses)
- Rate limiting on auth/rides/bookings/payments
- HTML-escape sanitize middleware on request bodies
- JWT auth with bcrypt password hashing
- Sequelize ORM with SQLite (dev) / PostgreSQL (prod intent)
- PM2 process management for API
- Responsive Tailwind CSS layout

Appendix B â€” Tools used to find these bugs

Every tool that helped during testing, and exactly what it was used for.

#	Tool	What we used it for
1	**Playwright (Python)**	Drove the browser like a real user: opened pages, clicked, filled forms, emulated phones/tablets (iPhone SE, iPhone 14, Galaxy S), and saved screenshots as proof.
2	**Google Chrome + Chrome DevTools**	Watched the console for JavaScript errors, watched the network for failing API calls, and switched to mobile view to check responsive layout.
3	**Chrome headless**	Ran Chrome without a window to render pages and to print the final report to PDF.
4	**Python 3 + requests library**	Sent crafted HTTP requests straight to the app's API (bypassing the UI) to test inputs, permissions and business rules.
5	**Python ThreadPoolExecutor**	Simulated several users doing things at the same time (for example, two students racing to grab the last seat).
6	**PowerShell / curl**	Quick one-off checks of URLs, headers, status codes and payloads.
7	**Source-code review (VS Code + GitHub)**	Read the app's own code and repository files to find hidden dangers such as committed passwords and the database being wiped on server restart.
8	**Git / GitHub**	Fetched the project source code, kept evidence organised, and published this report package.
9	**JWT decoder**	Read and re-built login tokens to test what the server accepts (fake/expired/other-user tokens).
10	**HTML report pipeline (Python + pypdf)**	Built these PDF/Word reports, added charts, and stamped page numbers on every page.

Appendix C â€” Testing techniques applied (133)

All 133 technique types that were actually executed, with the exact way each was used. This is the "100+ techniques" list required by the assignment.

#	Technique	Type	How it was applied
1	Unit testing	Level	Code-level verification via source review
2	Integration testing	Level	API endpoint + controller + model via HTTP
3	System testing	Level	End-to-end app behaviour on production URL
4	Acceptance testing (UAT)	Level	Journey checks against business rules
5	End-to-end testing	Level	Playwright browser journeys across pages
6	Regression testing	Level	Re-runs of critical paths after each phase
7	Smoke testing	Level	Health check + home/login/search baseline
8	Sanity testing	Level	Focused checks on booking and auth flows
9	Black-box testing	Approach	Behaviour driven by UI/API only
10	White-box testing	Approach	Source-informed tests (controllers, models)
11	Grey-box testing	Approach	Combined API knowledge + UI observation
12	Static testing	Approach	Code/config review without execution
13	Dynamic testing	Approach	Execution of app against live URL
14	Exploratory testing	Approach	Session-based unscripted exploration
15	Ad-hoc testing	Approach	Impromptu checks while navigating features
16	Error guessing	Approach	Intuition on seats, JWT, payments defect areas
17	Script-based testing	Approach	Python Playwright + requests evidence scripts
18	Equivalence partitioning	Method	Valid/invalid partitions for email, seats, price
19	Boundary value analysis	Method	0/-1/1/7/8 seats, rating 0/5/99, password 5/6
20	Decision table testing	Method	Booking rules combinations
21	State transition testing	Method	Ride/booking/payment status machines
22	Cause-effect graphing	Method	Input conditions to booking/payment outcomes
23	Pairwise / combinatorial testing	Method	Vehicle x seats x price x AC x date
24	Domain testing	Method	Karachi areas and seat domain 1-7
25	Comparison testing	Method	UI result vs direct API result
26	Scenario testing	Method	Real student commute scenarios (FAST-NUCES)
27	Business workflow testing	Method	Full carpool lifecycle journeys
28	Functional testing	Functional	Auth, rides, bookings, messages correctness
29	Business logic testing	Functional	Seat math, amountPaid, own-ride rule
30	Workflow testing	Functional	Offer ride -> book -> confirm -> complete
31	CRUD testing	Functional	Create/Read/Update/Delete entities
32	Form validation testing	Functional	Required fields, types, ranges on forms
33	Search / filter testing	Functional	Origin/destination/seats/price filters
34	Sorting / pagination testing	Functional	Ride list order and limit/offset

35	Booking lifecycle testing	Functional	Create, confirm, cancel, complete, rate
36	Payment flow testing	Functional	Method selection, success, double-pay, refund
37	Messaging testing	Functional	Send, conversations, empty content, XSS
38	Profile management testing	Functional	View/update profile fields
39	Rating / review testing	Functional	Review creation rules and bounds
40	Notification / badge testing	Functional	Unread message badge behaviour
41	UI testing	UI	Visual layout, components, form controls
42	Usability testing	UI	Ease of tasks, error message clarity
43	Navigation testing	UI	Dead links, route handling, 404
44	Consistency testing	UI	Naming, spacing, colour consistency
45	Content / copy review	UI	Marketing claims vs reality
46	Empty-state testing	UI	Behaviour with no rides/bookings/messages
47	Loading-state testing	UI	Perceived performance during page load
48	Error-state testing	UI	Wrong password, invalid inputs, API failures
49	Confirmation dialog testing	UI	Destructive actions (cancel ride/booking)
50	Help text / affordance testing	UI	Labels and guidance completeness
51	Onboarding flow testing	UI	First-run experience for new users
52	Accessibility testing (WCAG)	UI	Alt text, labels, button names
53	Keyboard navigation testing	UI	Tab order / focusability spot checks
54	Screen reader compatibility check	UI	ARIA/label presence via DOM audit
55	Color contrast spot-check	UI	Visual inspection of text backgrounds
56	Internationalization readiness	UI	Date/currency/phone formats (PK)
57	Localization testing	UI	Currency Rs., phone +92, university names
58	RTL / language toggle review	UI	Urdu/English claims vs implementation
59	Cross-browser testing	Compatibility	Chromium + Firefox + WebKit render
60	Cross-platform testing	Compatibility	Linux host; engines covering Win/Mac
61	Responsive design testing	Compatibility	320-1920px viewport overflow checks
62	Device emulation testing	Compatibility	iPhone SE/14, Galaxy S, iPad sizes
63	Touch vs mouse testing	Compatibility	Mobile viewport tap targets
64	Screen resolution testing	Compatibility	360, 375, 390, 768, 1024, 1440 widths
65	Browser zoom / scaling review	Compatibility	Layout at high DPI viewports
66	Dark/light theme review	Compatibility	Theme consistency where applicable
67	Load testing	Performance	Search API large limit; page load timing
68	Stress testing	Performance	limit=999999 query abuse check
69	Spike testing	Performance	Rapid sequential API calls

70	Endurance / soak awareness	Performance	Long-lived JWT / session design review
71	Volume testing	Performance	Large payload registration
72	Scalability review	Performance	Caching, pagination, query patterns
73	Concurrency / race condition testing	Performance	Seat decrement without transaction
74	Latency testing	Performance	Navigation timing on home page
75	Bundle / resource size review	Performance	Asset sizes via network metrics
76	Bandwidth throttling review	Performance	Mobile viewport behaviour
77	Offline / network error testing	Performance	API fallback to mock data
78	CPU / memory spot-check	Performance	Headless browser session stability
79	Authentication testing	Security	Login/logout, wrong password, empty password
80	Authorization testing	Security	Protected routes without/with invalid JWT
81	Session management testing	Security	JWT localStorage, 7-day expiry, revoke gap
82	Token security testing	Security	Garbage token, payload tampering rejection
83	OWASP Top 10 review	Security	Mapped findings to OWASP categories
84	XSS testing	Security	Stored/reflected payloads in name, notes, messages
85	SQL injection testing	Security	Parameter fuzzing via ORM usage review
86	CSRF testing	Security	Bearer-token architecture reduces classic CSRF
87	IDOR / broken access control testing	Security	Cross-user booking/ride/profile access
88	Mass assignment testing	Security	Extra fields on ride create/update
89	Privilege escalation testing	Security	Passenger self-confirm, self-verify
90	Account enumeration testing	Security	Login responses for unknown vs wrong password
91	Brute force / rate limiting testing	Security	Burst requests on unprotected routes
92	Password policy testing	Security	Min length 6, complexity expectations
93	Input validation / fuzzing	Security	Invalid email/phone/status/limit params
94	Security header testing	Security	CSP, XFO, HSTS, Permissions-Policy audit
95	HTTPS / transport testing	Security	HSTS header present on live site
96	CORS testing	Security	Evil origin probe on API
97	Sensitive data exposure testing	Security	Phone/PII in public APIs
98	Error message leakage review	Security	Generic vs verbose error strings
99	Injection in API parameters	Security	Query/body fuzzing via script
100	API testing	API	All auth/rides/bookings/payments/messages endpoints
101	HTTP method testing	API	GET/POST/PUT usage per REST design
102	HTTP status code testing	API	200/201/400/401/403/404/500 behaviour
103	Content-type / payload testing	API	JSON body handling
104	Response schema / contract testing	API	success/message/data shape consistency

105	Pagination / limit testing	API	limit/offset parameters
106	Database constraint testing	API	Sequelize validation min/max/isEmail/is
107	Data integrity testing	API	Seat inventory before/after cancel
108	Transaction / ACID review	API	Missing transaction on booking seat update
109	Seed data validation	API	Demo users/rides from backend boot seed
110	Migration / sync behavior testing	API	sequelize.sync force:true impact
111	Reliability testing	Non-functional	DB wipe on restart, mock fallback
112	Recovery testing	Non-functional	Behaviour after failed booking/payment
113	Install / deploy config review	Non-functional	Procfile, render.yaml, PM2, Caddy
114	Documentation review	Non-functional	README claims vs implemented features
115	SEO / metadata testing	Non-functional	Title, meta tags on live HTML
116	Dead-link testing	Non-functional	Forgot password and nav links
117	Logging / console error review	Non-functional	Browser console during critical pages
118	Health-check testing	Non-functional	GET /api/health
119	Maintainability observation	Non-functional	Code smells reported as QA findings
120	Process / QA readiness review	Non-functional	Absence of automated tests
121	Configuration security review	Non-functional	Hardcoded secrets, CORS allowlist
122	Session-based exploratory testing	Exploratory	Time-boxed exploration notes per module
123	Monkey / random testing	Exploratory	Random invalid params and rapid clicks
124	Key-tour testing	Exploratory	Critical path tours without detailed scripts
125	Persona-based testing	Exploratory	Student passenger vs driver personas
126	Crowd-style scenario testing	Exploratory	Multiple concurrent user roles via API
127	Data-driven testing	Exploratory	Scripted datasets for seats/price/status
128	Mutation-style input testing	Exploratory	Mutating valid requests with invalid fields
129	Chaos awareness review	Exploratory	Backend restart impact (DB wipe)
130	Accessibility regression spot-check	Exploratory	Repeat label/alt audits
131	Performance budget check	Exploratory	Home load timing vs expectations
132	Cross-session data check	Exploratory	Data persistence across browser sessions
133	Error recovery path testing	Exploratory	What user sees after failures

Appendix D â€” Helpful internet links & standards (52)

The books, standards, articles and documentation pages that guided the testing and the writing of these oracles.

#	Reference	URL (clickable)
1	ISO/IEC 25010:2011 Systems and software Quality Requirements and Evaluation (SQuaRE)	https://www.iso.org/standard/35736.html
2	ISO/IEC 25023:2016 SQuaRE Measurement of system and software product quality	https://www.iso.org/standard/64774.html
3	ISTQB Foundation Level Syllabus 2018	https://www.istqb.org/certifications/foundation-level
4	ISTQB glossary of testing terms	https://glossary.istqb.org
5	OWASP Top 10 (2021)	https://owasp.org/www-project-top-ten/
6	OWASP Testing Guide	https://owasp.org/www-project-web-security-testing-guide/
7	OWASP XSS Prevention Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html
8	OWASP Broken Access Control (IDOR)	https://owasp.org/Top10/A01_2021-Broken_Access_Control/
9	OWASP Mass Assignment / Over-posting	https://owasp.org/www-community/attacks/Mass_assignment
10	OWASP SQL Injection Prevention Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
11	OWASP Authentication Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
12	OWASP Session Management Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
13	OWASP API Security Top 10 (2023)	https://owasp.org/API-Security/editions/2023/en/0x11-t10/
14	CWE-639: Authorization Bypass Through User-Controlled Key (IDOR)	https://cwe.mitre.org/data/definitions/639.html
15	CWE-79: Cross-site Scripting	https://cwe.mitre.org/data/definitions/79.html
16	CWE-862: Missing Authorization	https://cwe.mitre.org/data/definitions/862.html

17	CWE-863: Incorrect Authorization	https://cwe.mitre.org/data/definitions/863.html
18	W3C Web Content Accessibility Guidelines (WCAG) 2.1	https://www.w3.org/TR/WCAG21/
19	W3C Web Accessibility Tutorials	https://www.w3.org/WAI/tutorials/
20	Mozilla MDN CORS	https://developer.mozilla.org/en-US/docs/Web/HTTP/CORS
21	Mozilla MDN HTTP security headers	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers
22	Mozilla MDN Web Storage API	https://developer.mozilla.org/en-US/docs/Web/API/Web_Storage_API
23	Mozilla MDN Responsive design	https://developer.mozilla.org/en-US/docs/Learn/CSS/CSS_layout/Responsive_Design
24	JWT.io Introduction to JSON Web Tokens	https://jwt.io/introduction
25	RFC 7519 JSON Web Token (JWT)	https://tools.ietf.org/html/rfc7519
26	Microsoft Learn REST API design best practices	https://learn.microsoft.com/en-us/azure/architecture/best-practices/api-design
27	Sequelize documentation Validations	https://sequelize.org/docs/v6/core-concepts/validations/
28	Sequelize dialect-specific things (SQLite/Postgres)	https://sequelize.org/docs/v6/other-topics/dialect-specific-things/
29	Express.js security best practices	https://expressjs.com/en/advanced/best-practice-security.html
30	Helmet.js	https://helmetjs.github.io/
31	express-rate-limit	https://github.com/express-rate-limit/express-rate-limit
32	Playwright documentation	https://playwright.dev/docs/intro
33	Python requests documentation	https://requests.readthedocs.io/
34	Karl Wiegers Writing effective defect reports	https://www.processimpact.com/articles/bug_report.html
35	James Bach Session-based exploratory testing	https://www.satisfice.com/blog/archives/278
36	Michael Bolton The oracle problem	https://www.developsense.com/blog/2009/08/the-oracle-problem/
37	IEEE 829 Test Documentation standard (reference)	https://standards.ieee.org/ieee/829/4317/

38	ISTQB Defect / Defect lifecycle	https://glossary.istqb.org/en_US/defect
39	Google developers Speed / PageSpeed Insights	https://developers.google.com/speed
40	web.dev Best Practices	https://web.dev/learn/
41	Can I use	https://caniuse.com/
42	Caddy documentation	https://caddyserver.com/docs/
43	PM2 documentation	https://pm2.keymetrics.io/docs/usage/quick-start/
44	React documentation	https://react.dev/learn/managing-state
45	Vite documentation env variables	https://vitejs.dev/guide/env-and-mode.html
46	React Router documentation	https://reactrouter.com/home
47	NIST SP 800-63B password guidelines	https://pages.nist.gov/800-63-3/sp800-63b.html
48	CampusPool live deployment	https://carpool.33.jugaar.ai
49	CampusPool API health	https://carpool.33.jugaar.ai/api/health
50	CampusPool source (local repo README)	file:///root/campuspool/README.md
51	CampusPool DEPLOYMENT guide (local)	file:///root/campuspool/DEPLOYMENT.md
52	Course defect-report format reference (Lewis-style)	https://www.processimpact.com/articles/bug_report.html